Sri Lanka Institute of Information Technology



Assignment 1

Network Security | IE3132

Y3.S1.WE.CS.02

IT Number	Name
IT24102747	Kosgollage S R
IT24201195	Palugaswewa K I K I B
IT24102899	Shaheen M F M
IT24102514	Aaqib H M

Contents

Member Contribution 3

Introduction / Scenario Summary 1

2. Individual Threat Modeling 3

Threat 1 (Kosgollage S R – IT24102747): Exploitation of known vulnerabilities in unpatched branch workstation software/OS 3

Threat 2: Data exposure via unmanaged personal devices on the network 3

Threat 3: (Aaqib H M - IT24102514) Rogue Device / Network Tap via Unlocked Branch Networking Cabinets 4

Threat 4: Credential Stuffing / Account Takeover (Password Reuse & Sharing) 4

Threat 5: (Palugaswewa K I K I B - IT24201195) Ransomware deployed via phishing email spreading across the unsegmented flat network 5

Threat 6: Unauthorized access using the shared, non-individual VPN credential 6

Threat 7: (Shaheen M F M - IT24102899) - Compromise of Northbridge data via a breached third-party payment processing partner 6

Threat 8: Undetected reconnaissance or active compromise due to no IDS/IPS 7

3. Layered Security Plan 8

3.1 Numbered Master List of Controls 8

3.2 Control-to-Threat/Attack 9

3.3 Function × Category Dual-Axis Table 9

3.4 Control Minimization Justification 9

4. Individual Technology Proposals 12

5. Group Technology Evaluation & Selection 13

5.1 VPN Solution 15

5.2 AAA Solution 16

5.3 Secure Network Architecture 17

5.4 IDS / IPS Solution 19

6. Network Hardening Configurations 22

7. Conclusion 61

8. Appendices 62

Appendix A: Kosgollage S R - IT24102747 62

Appendix B: Aaqib - IT24102514 68

Appendix C: Shaheen M F M - IT24102899 72

Appendix D: Palugaswewa K I K I B - IT24201195 75

Member Contribution

Member	Threats	Technologies				Configurations	
		VPN	AAA	NA	IDS/IPS	Planned	Free
Kosgollage S R IT24102747 Appendix A	Threat 1 Threat 2	Cisco AnyConnect (SSL VPN)	Cisco ISE	Hub and spoke architecture with branch level firewalls	Cisco Secure IPS	Port security	DHCP snooping
Palugaswewa K I K I B IT24201195 Appendix D	Threat 5 Threat 6	Palo Alto Networks Global Protect	Aruba ClearPass Policy Manager	Secure SD – WAN with distributed NGFW zone enforcement	Palo Alto Networks	VLAN segmentation	SSH Configuration for Secure Device Management
Shaheen M F M IT24102899 Appendix C	Threat 7 Threat 8	WireGuard-based VPN (Tailscale /self-hosted)	FreeRADIUS + centralized LDAP/AD	Defense-in-depth with function-based micro-segmentation	Zeek (network monitoring/ detection engine)	AAA configuration	VPN (Site to site IPsec)
Aaqib H M IT24102514 Appendix B	Threat 3 Threat 4	FortiClient IPsec VPN (Fortigate NGFW)	FortiAuthenticator (RADIUS + FortiToken MFA)	Three tier Zone architecture (HQ) + Router based Zone firewall (branches)	Suricata (open-source IDS/IPS)	Zone based firewall	ACL for inter VLAN filtering

Introduction / Scenario Summary

Northbridge Savings & Finance is a mid-sized regional financial institution providing personal banking, small business loans, and payment services. Its main office and six other branches across the region employ approximately 450 people. The bank's core banking application and customer database reside in a private Data Centre located in the main office, while the online banking portal and application are publicly accessible over the Internet. The six regional branches are connected to the main office over secured links. The bank's operational needs also include limited remote access to the banking system for a few traveling and telecommuting employees and two contracting IT service providers. Northbridge is also in the process of adopting two external payment processing platforms, which should be integrated into the existing system within the next two quarters.

The bank has traditionally focused on physical security measures such as vaults, alarms, and surveillance cameras at its facilities without significant IT security investments. As a result, the network infrastructure was deployed in an improvised manner and has remained the same for over ten years. The systems supporting the corporate office, regional branches, public wireless access points, and point-of-sale equipment are using the same flat network. Similarly, remote access to the banking system is provided through a shared virtual private network (VPN) account that is unsecured, lacks individual accountability, and does not use multi-factor authentication. The bank does not have dedicated firewall protection, intrusion detection or prevention system, or central authentication server. Each IT asset and application uses its own local user account management system secured by default, with no central security visibility and control.

In the past two months, Northbridge experienced two security incidents that drew the C-level executives' attention to the insufficient cyber-security posture. The first incident was a ransomware attack that is common in the regional financial industry. According to the industry's security newsletter, several mid-size banks have been impacted by encrypting malware distributed through a regional ransomware campaign. It is suspected that the malware initially accessed the banking system through a single compromised branch office computer and later spread across all systems because they were connected with a flat network.

In the second incident, one of the employees received a fraudulent phone call from the scammer, who identified himself as the IT Helpdesk and asked to provide the account credentials. Fortunately, the employee did not disclose the information and was able to terminate the call. However, Northbridge's current cyber-security practices do not include any employee security awareness training or response procedures to such attacks. The bank's CTO has initiated a capital project to review and upgrade the cyber-security infrastructure, and this report was developed as a part of this project.

Key Assets

The most critical asset is the customer financial and personal data stored in the core banking database along with the online banking portal and mobile application, which customers use to access their accounts. Other key assets are the connectivity between the branches and the head office, the internal email system with staff's credentials, and the upcoming integration with the two third-party payment partners, which will be the first to extend trust beyond Northbridge's own infrastructure. The underlying aspect of all of the above is the bank's regulatory status and public reputation, as its ongoing operations depend on the customers' and regulators' confidence as much as any single system's uninterrupted functioning.

Notable Current Weaknesses

The review uncovered several deficiencies in the three areas:

- Technical: there was no multi-factor authentication mechanisms in place; shared single-use VPN account without individual authentication; no segmentation of networks; lack of intrusion detection/prevention mechanisms; absence of any formal patch management, with some branch systems running on out-of-date operating systems and applications; and no centralized logging or audit trail.
- Physical: the head office server room was protected only by a single shared key with no camera or auditable access records; branch office visitor sign-ins were inconsistently enforced; there was no visible signage, badge checking or cameras at entry points to any site; and networking cabinets were found to be unsecured in at least two branch offices.
- Administrative: there was no data classification policy; no security assessment procedure for vendors who provide the payment integration; no guidelines for staff working from home or using personal devices; passwords were commonly shared and reused by staff in different branches; backups had never been tested for their ability to restore; there was no documented disaster recovery or incident response plan; and no security awareness training programme.

Scope and Approach of this Report

This report contains the group's security review and proposed upgrade for Northbridge. Each of the four group members independently modelled two threats with the asset, vulnerability, threat, exploit, attack, impact, and risk approach resulting in 8 threats total. This was aggregated by the group into one layered security plan of numbered controls, with a control-to-threat mapping, a Function × Category categorization, and a rationale of how the number of controls are minimized. Furthermore, each of the four group members had also independently proposed solutions for the four mandatory technology areas (VPN, AAA, secure network architecture, and IDS/IPS) which had been compared and one final recommendation per technology area selected. Finally, the four group members each implemented two network hardening configurations in Cisco Packet Tracer as practical evidence of the recommendations.

2. Individual Threat Modeling

Risk rating (5×5 likelihood × impact scale (L 1–5, I 1–5; 1–6 Low, 7–14 Medium, 15–25 High))

Threat 1 (Kosgollage S R – IT24102747): Exploitation of known vulnerabilities in unpatched branch workstation software/OS

Component	Details
Asset	Branch office workstations and network pathways toward head office systems
Vulnerability	There is no formal patch management process, and several branch systems are known to run outdated OS/application versions
Threat	An outside attacker or worm scans the network for known vulnerabilities
Exploit	A publicly known vulnerability (CVE) with an associated exploit targeting the vulnerability is used to exploit the weakness and gain remote code execution on the branch office workstation
Attack	Attacker compromises the unpatched workstation as an initial foothold, then leverages the flat, unsegmented network to move laterally toward head office systems
Impact	The initial foothold is used to move laterally within the network, stealing data or providing a bridge to attack the mainframe systems or core banking systems
Risk rating	(L4 × I5 = 20, High): the scenario confirms several branch machines run outdated OS/applications and no patching process exists; the flat network gives any compromised branch host direct reach to head office across six branches.

Threat 2: Data exposure via unmanaged personal devices on the network

Component	Details
Asset	Sensitive customer and corporate data accessed or transmitted via staff owned personal devices
Vulnerability	No data classification policy and no BYOD/remote work security guidance, despite staff being permitted to use personal machines and phones for work and access the network remotely
Threat	Attacker or malware exploiting an unmanaged, unsecured personal device as an entry point or accidental data leakage due to lack of policy
Exploit	A personal device lacking endpoint protection becomes infected with malware, or connects directly to a switch port/network with no device authentication or restriction enforced
Attack	The infected or unauthorized personal device connects to the network and due to no port level or device level restriction, communicates freely with other systems enabling malware propagation, network reconnaissance or exposure of sensitive data cached on the device
Impact	Loss of exposure of sensitive customer / corporate data, and introduction of malware into the internal network via a device outside Northbridge's control
Risk rating	(L3 × I4 = 12, Medium-High): personal devices are allowed with no rules, but exposure depends on a device being compromised or lost; data is customer financial data, so impact is high

Threat 3: (Aaqib H M - IT24102514) Rogue Device / Network Tap via Unlocked Branch Networking Cabinets

Component	Details
Asset	Branch network infrastructure — switches, LAN traffic, and connected systems (workstations, POS devices) at branch back offices
Vulnerability	Physical access to networking equipment in branch back offices is uncontrolled; cabinets found unlocked in at least two locations during a recent walkthrough, with no port-level access restrictions on switches
Threat	A malicious insider, opportunistic intruder, or unauthorized third party (e.g., visiting contractor) with physical access to an unlocked cabinet
Exploit	Exploiting the lack of physical security and lack of port security to physically connect an unauthorized device (rogue laptop, network tap, or rogue switch) directly into the branch's flat network
Attack	Attackers plug a rogue device into an open switch port in an unlocked cabinet, then performs passive traffic sniffing, DHCP spoofing, or ARP poisoning to intercept or manipulate branch traffic
Impact	Interception of sensitive traffic (credentials, banking data in transit), potential foothold for further lateral movement into head office systems due to the unsegmented flat network, and undetected presence since there's no centralized logging
Risk	(L3 × I4 = 12, Medium-High): unlocked cabinets were observed in two branches, but exploitation needs physical presence; there is no port security, DHCP snooping or DAI, and no CCTV or logs, so an intruder would be undetected.

Threat 4: Credential Stuffing / Account Takeover (Password Reuse & Sharing)

Component	Details
Asset	User accounts on branch workstations and applications (each device/app keeps its own local accounts)
Vulnerability	Widespread password reuse and password sharing among branch staff; no centralized AAA system, no password policy enforcement, no MFA anywhere
Threat	External attacker (or malicious insider) using leaked/breached credentials, or exploiting shared passwords among staff

Exploit	Reused passwords from unrelated public data breaches are tried against Northbridge logins; shared passwords mean one leaked credential opens multiple accounts
Attack	Credential stuffing attack — automated login attempts using known leaked username/password pairs against branch login portals/local accounts
Impact	Unauthorized access to branch systems, enabling lateral movement across the flat, unsegmented network toward core banking data; likely undetected due to no centralized logging
Risk	(L4 × I4 = 16, High): password reuse and sharing are described as common among branch staff and there is no MFA anywhere; one leaked credential works across several systems.

Threat 5: (Palugaswewa K I K I B - IT24201195) Ransomware deployed via phishing email spreading across the unsegmented flat network

Component	Details
Asset	Branch workstations, branch-to-head-office network links, head office systems, and the core banking/customer data they support
Vulnerability	Phishing-prone users and no security awareness programme; flat, unsegmented network allows a compromised branch workstation to communicate broadly; no IDS/IPS capability
Threat	External threat actor delivering ransomware through a phishing email to a Northbridge branch employee
Exploit	A malicious attachment or link executes ransomware on a branch workstation, giving the attacker an initial foothold and access to the workstation's credentials and network connectivity
Attack	The ransomware encrypts the compromised workstation and then uses the flat network to discover and reach other branch and head-office systems, potentially using shared credentials or exposed services for lateral movement
Impact	Widespread service disruption and loss of access to core banking systems; possible customer-data compromise; financial loss, regulatory consequences, reputational damage, and disruption to the upcoming payment-processor integration
Risk	(L5 × I5 = 25, High): the regional industry association is already reporting this pattern at comparable firms; there is no training, no segmentation and no IPS.

Threat 6: Unauthorized access using the shared, non-individual VPN credential

Component	Details
Asset	Northbridge's remote-access VPN, internal systems reachable through the VPN, and the accounts/data accessible to remote staff and external IT support contractors
Vulnerability	All remote staff and contractors use one shared VPN account; there is no individual accountability, no MFA, no centralized authentication, and no centralized audit trail
Threat	Malicious external actor obtaining the shared VPN credential, or a contractor/remote user deliberately misusing the shared account
Exploit	The shared credential is obtained through phishing, password disclosure, credential reuse, or contractor misuse, then used to authenticate successfully to the VPN because the system cannot distinguish the legitimate individual from the attacker
Attack	The attacker establishes a legitimate-looking VPN session, accesses internal resources allowed to the shared account, and can move further into the flat internal network or abuse accessible systems without a reliable individual identity being recorded
Impact	Unauthorized access to internal banking resources, possible theft or modification of sensitive data, deployment of malware or ransomware, loss of accountability, and difficulty identifying or revoking only the affected user or contractor
Risk	(L4 × I5 = 20, High): one shared VPN account with no MFA is used by remote staff and two outside contractors, so a single phished or disclosed password gives remote access with no way to attribute or revoke it individually.

Threat 7: (Shaheen M F M - IT24102899) - Compromise of Northbridge data via a breached third-party payment processing partner

Component	Details
Asset	Core banking database and the new payment partner integration link
Vulnerability	No network segmentation, and no vendor security assessment process for the incoming partners
Threat	An attacker compromises one of the two payment partners and uses that trusted connection to get into Northbridge's network
Exploit	With no DMZ separating partner traffic from internal systems, the attacker rides the compromised partner connection straight into the internal network
Attack	Attacker moves from the partner link into the head office network and reaches the core banking database to steal or alter customer data
Impact	Customer data breach, regulatory penalties, reputational damage, financial loss
Risk	(L3 × I5 = 15, High): the integration goes live within two quarters, there is no vendor assessment and no DMZ, and a partner breach would arrive over a trusted link straight to the core banking environment.

Threat 8: Undetected reconnaissance or active compromise due to no IDS/IPS

Component	Details
Asset	Core banking database and head-office management systems; the audit trail needed to prove what happened to regulators
Vulnerability	No IDS/IPS, no centralized logging, local per-device accounts, flat network; every site has separate logs nobody reviews
Threat	A skilled external attacker (or a contractor using the shared VPN account) who gains a foothold and stays hidden for weeks to map the network and harvest data before acting
Exploit	Valid but stolen credentials or a vulnerable branch host give initial access; the absence of monitoring means port scans, SMB/RDP enumeration and bulk data staging raise no alert
Attack	Quiet reconnaissance (MITRE T1046), credential harvesting, lateral movement toward the head-office core banking segment, then staged exfiltration of customer records
Impact	Long-dwell breach of customer financial data, regulatory reporting failure under the PDPA, inability to reconstruct events for forensics, reputational harm ahead of the payment-partner go-live
Risk	(L4 × I4 = 16, High) likelihood is raised because nothing at Northbridge would detect the activity; impact is severe because the data is the bank's most critical asset

3. Layered Security Plan

3.1 Numbered Master List of Controls

ID	Control	Description
C1	Network segmentation	Divides the flat network into isolated zones (VLANs, firewall-enforced boundaries) so that a compromise in one segment cannot freely reach others, containing the spread of attacks such as ransomware.
C2	Centralized AAA	Replaces local, per-device accounts and the shared VPN credential with a single, centrally managed authentication, authorization, and accounting system supporting individual accountability and MFA.
C3	Port security	Restricts which device MAC addresses may connect to a given switch port, preventing rogue or unauthorized devices from gaining a live connection to the network.
C4	DHCP snooping	Prevents unauthorized or rogue DHCP servers from assigning IP addresses on the network, blocking a common technique used to intercept or redirect client traffic.
C5	Dynamic ARP Inspection	Validates ARP packets against the DHCP snooping binding table, blocking spoofed ARP messages used to redirect or intercept traffic between devices on the same segment.
C6	Patch management Program	Establishes a formal process for identifying, testing, and applying software and OS updates across branch and head office systems, closing known vulnerabilities before they can be exploited.
C7	Third party vendor security assessment process	Requires formal security evaluation of external partners, such as the incoming payment processors, before integration, ensuring trust extended beyond Northbridge's own infrastructure is justified.
C8	Data classification & BYOD/ Remote work policy	Defines which data must be encrypted, restricted, or handled with care, and sets security rules for staff using personal devices or working remotely, addressing gaps with no current guidance.
C9	IDS/IPS and centralized logging	Deploys intrusion detection/prevention at the head-office and branch firewalls and collects firewall, IPS, switch and AAA logs centrally with alerting, so reconnaissance, lateral movement and policy violations are detected and, where possible, blocked.
C10	Physical access control to network equipment	Locks, access-logged entry and CCTV for branch networking cabinets and the head-office server room, plus signage and a visitor sign-in procedure, preventing and deterring unauthorized physical connection of devices.
C11	Security awareness and phishing/vishing training	Regular training and simulated phishing for all staff, with a simple "verify and report" procedure for suspicious emails and calls, reducing phishing success and password sharing.

C12	Backup, disaster recovery and incident response	Tested backups (including offline/off-site copies), a documented DR plan and an incident response procedure, so data and services can be restored and attacks contained after a compromise.

3.2 Control-to-Threat/Attack

Control	Threats addressed
C1	T1,T5,T7, T8
C2	T4, T6
C3	T2, T3
C4	T3
C5	T3
C6	T1, T8
C7	T7
C8	T2
C9	T1
C10	T3
C11	T4, T5
C12	T5, T8

3.3 Function × Category Dual-Axis Table

Category	Administrative	Technical	Physical
Preventive	C6, C7, C8,C11	C1, C2, C3, C4, C5, C6, C9	C10
Detective	C11	C2, C3, C5,C9	C10
Deterrent	C8	C2	C10
Corrective	C6,12	C6	-
Recovery	C12	C12	C12
Compensating	-	C3, C5, C9	-

Both Corrective–Physical and Compensating–Physical categories are empty; there are no controls in this plan that perform either of these functions. Notes on the placement: C2 is deterrent since named accounts should make the attempted misuse obvious; C9 is compensating since the IPS provides virtual patching while the C6 patching is incomplete; C10 is physical for the cabinets and server room, and C12 is physical by having its off-site/offline copies; C11 is detective since trained staff may report any suspicious calls or emails.

3.4 Control Minimization Justification

In the designing process of the layered security plan, there was a deliberate choice to focus on the breadth of coverage rather than the number of controls selected for inclusion. Instead of selecting one control per each of the eight threats modeled individually, the group focused on a

small number of high-leverage controls, each of which addressed several threats or significantly increased the difficulty of achieving simultaneous attacks.

The most evident example of controls that covered multiple threats were the network segmentation measures (C1), specifically the VLAN, zone-based firewall, and access control lists that address the propagation of ransomware from an infected host (T5), lateral movement after the exploitation of unpatched software (T1), the traffic of third-party payments (T7), and the ability of an intruder to conduct reconnaissance (T8). The four threats were grouped together by the common opportunity Northbridge's flat network architecture provided for an attacker to freely move from one host to another after initial exploitation. The segmentation controls addressed the root cause of the four threats, thus rendering several individual controls unnecessary. Another example of coverage breadth was the choice of AAA (C2) as the control to mitigate both the misuse of the shared VPN credential (T6) and credential stuffing (T4). In both cases, the threat was rooted in the lack of individual accountability and central control of authentication, which would be addressed by the implementation of AAA solutions. Lastly, the selection of port security (C3) as the mitigation measure for both rogue switches (T5) and BYOD-related unmanaged devices (T2) was justified by the similarity of the attack vectors, which would be eliminated by restricting unauthorized access to the network via ports.

The group did consider narrower alternatives to these broader controls before settling on them. For example, a control specific to anti-lateral-movement targeting only ransomware containment was considered for T5, but it would have been redundant with the existing network segmentation controls, adding nothing in terms of coverage for T1, T7, or T8 that isn't already covered by C1, so it was rejected in favor of relying on C1 alone. Similarly, one control was considered for a separate device-authentication mechanism for BYOD devices (T2), but since port security already restricts which devices can communicate on the network, regardless of their ownership, having a second, narrower control would have been redundant.

We considered adding a control specifically over the remote – access VPN as a measure to address T6 (unauthorized access via shared VPN credential) but decided against it for the control set. Closer inspection shows that the VPN tunnel itself is not what causes the vulnerability in T2 – the problem was the shared, uncircumscribed credential used to authenticate to it, not the encryption/authentication mechanism by which it was accessed. This is already addressed by C2, which removes the possibility of a shared credential by introducing individually authenticated, centrally administered access. Adding a control directly over the VPN would have addressed the same problem a second time – not an optimal choice for a Layered Security Plan control set. The group's recommended VPN solution (Sections 4 and 5) is delivered through C2, so no separate control is needed.

At the same time, we were careful not to over-consolidate controls, where doing so would have weakened the accuracy of the plan. Patch management (C6) was kept as a standalone control, rather than folded into network segmentation, because segmentation only limits how far an attacker can travel after a workstation is compromised, not the T1, the unpatched vulnerability itself. Collapsing this into a single control would have misrepresented how the threat is mitigated. Likewise, the third-party vendor security assessment process (C7) and the data classification and BYOD policy (C8) were kept completely separate from the technical controls,

since T7 and T2 stem from administrative and governance gaps – the absence of a vendor vetting process and the absence of data-handling guidance – that no technical control can substitute for, however broad.

Finally, the group deliberately chose to accept a degree of redundancy between DHCP snooping (C4) and Dynamic ARP Inspection (C5). In practice, these two controls are intimately related, given that DAI depends upon the DHCP snooping binding table to determine valid ARP traffic, and both primarily focus on the same threat (T3), with DAI offering additional value against traffic interception by ARP poisoning **(T3)**, which DHCP snooping alone does not stop. By choosing to report them as two entries instead of combining the efforts into a single 'Layer 2 hardening' control, the group opted for a slightly less accurate but easier-to-report perspective, given that these two are configured and audited as two separate features in practice, with the overlapping character of the protection scope explicitly acknowledged.

Cross-checking of the eight threats with the initial eight controls revealed four gaps, which were not addressed by the existing controls. Specifically, there was nothing to detect the unauthorized activity in T8 or the lack of logging in T3, T4, and T8; nothing to prevent unauthorized access to the unlocked cabinets in T3; nothing to raise awareness of the human factor behind T5 and T4; and nothing to recover data in the case of ransomware attack in T5 and T8. Thus, new controls were added as C9-C12 instead of expanding existing ones (C1-C8). In addition, each of the new controls is broad enough to address multiple threats. For example, the combination of IDS/IPS (intrusion detection/prevention system) and centralized logging in C9 was used, since both would be necessary for detecting a threat, while the IPS would serve as a protective measure. Similarly, the response to ransomware in C12 requires not only regular backups but also disaster recovery and incident response plans. The redundancy between some of the newly established controls was justified by the fact that a single security tool might fail to provide sufficient protection. For instance, IPS in C9 compensates for the potential delay in patch management in C6, while the port security in C3 is used as a backup to the physical access controls in C10 in the case of unlocked cabinets. Finally, the standalone host management and 802.1X authentication on every port were discarded due to the high costs and complexity of implementation across seven locations.

4. Individual Technology Proposals

Member	VPN	AAA	Network architecture	IDS / IPS
Kosgollage S R	Cisco AnyConnect (SSL VPN)	Cisco ISE	Hub and spoke architecture with branch level firewalls	Cisco Secure IPS
Palugaswewa K I K I B	Palo Alto Networks Global Protect	Aruba ClearPass Policy Manager	Secure SD – WAN with distributed NGFW zone enforcement	Palo Alto Networks
Shaheen	WireGuard-based VPN (Tailscale/self-hosted)	FreeRADIUS + centralized LDAP/AD	Defense-in-depth with function-based micro-segmentation	Zeek (network monitoring/detection engine)
Aaqib	FortiClient SSL VPN (Fortigate NGFW)	FortiAuthenticator (RADIUS + FortiToken MFA)	Three tier Zone architecture (HQ) + Router based Zone firewall (branches)	Suricata (open-source IDS/IPS)

The justification for each individual proposal is in the Appendices section (Appendices A–D)

5. Group Technology Evaluation & Selection

A comparison of the four members' proposals in Section 4 was conducted in two stages. As the firewall platform accounts for most of the cost and determines the compatibility of the VPN, AAA and IPS components, the group first compared the complete technology platforms (Stage 1) and then compared proposals within each technology area (Stage 2). In the second stage, weighted criteria and a 1–5 score for each criterion were applied (Score: Σ(weight × score) 5 = total score out of 100). The cost criterion has the largest single weighting in both stages (20–35%) as Northbridge is a regional finance company that must achieve value for money, while the remainder reflects the security requirements identified in the scenario: individual accountability and MFA, containment of ransomware attack from a branch, and visibility of intrusions. The technologies selected implement the security plan in Section 3: the VPN and AAA components deliver C2, the architecture provides C1 (with C3–C5 fulfilled at Layer 2), and the IDS/IPS component delivers C9. The scores are the group's assessment; the cost scores are relative and should be compared with vendor quotes.

Criterion	Cisco stack (ISE, Secure Client, Secure Firewall/IPS)	Palo Alto + Aruba (GlobalProtect, ClearPass, NGFW)	Fortinet stack (FortiGate, FortiClient, FortiAuthenticator)	Open source only (WireGuard, FreeRADIUS, Suricata/Zeek)
Total cost of ownership: licenses, hardware, subscriptions (35)	2	1	4	5
Capability coverage of all four areas (25)	5	5	5	3
Single management plane / operational simplicity (20)	3	2	5	1
Vendor security track record and patching burden (20)	3	3	2	3

Weighted score	63	52	81	66

The Cisco stack is the most integrated and technically advanced, but its licensing for ISE, the Secure Client VPN, the firewalls, and the IPS subscription makes it the most expensive option for a company of Northbridge's size. Palo Alto with Aruba is a similar budget category but implies the necessity to use two vendors. An open-source stack has virtually no licensing costs but lacks a single point of management, vendor support, and native multifactor authentication, which would incur substantial opportunity costs in terms of the newly hired security staff's time. Fortinet covers all the necessary functions from a single vendor, utilizes VPN, IPS, and firewall licenses on the same devices, and, therefore, offers the best value compared to the rest. Its main weakness is the vendor's track record, as Fortinet's VPN products have been subject to numerous attacks, and the company discontinued support for SSL VPN tunneling mode in FortiOS 7.6.3, recommending customers to migrate to IPsec VPN. The group's response (a) designates IPsec VPN as the preferred standard and (b) relies on the patch management program (C6) to ensure that the latest firmware is always used.

Indicative cost shape (relative, not quotes)

Component	Cisco	Palo Alto + Aruba	Fortinet	Open source
Firewalls (HQ pair + 6 branches)	High	High	Medium	No cohesive NGFW
Remote access VPN	Medium (client licenses)	Medium	Low – medium (gateway included: endpoint compliance needs FortiClient EMS)	Low
AAA/MFA	High (ISE tiers)	High (ClearPass)	Medium (FortiAuthenticator + Fortitokens)	Low (software), High (labor)
IPS	Medium – High (subscription)	High	Low – medium (subscription, or free Suricata)	Low (software) High (labor)

5.1 VPN Solution

Comparative Evaluation

Criterion	Kosgollage: Cisco Secure Client (AnyConnect)	Palugaswewa: GlobalProtect	Shaheen: WireGuard / Tailscale	Aaqib: FortiClient IPsec VPN
Individual accountability + MFA (25)	4	4	2	5
Endpoint compliance for BYOD/contractors (15)	4	4	1	4
Integration with the selected AAA (10)	5	4	2	4
Fit with the selected platform (15)	2	2	2	5
Operational burden for the new team (15)	4	4	4	4
Cost (20)	2	2	5	3
Weighted score	68	66	49	84

Each of the four proposals can replace the shared, unaccountable Northbridge VPN account (T6) in use by providing a client via C2. GlobalProtect, AnyConnect and FortiClient are established commercial products with multifactor authentication and central policy control; Wireguard is much lighter but lacks enterprise grade AAA integration and multifactor auth, and leaves the critical distribution and revocation of keys to Northbridge, which undercuts the scenario's stated requirement to eliminate individual accountability and multifactor auth. Between the commercial products, the main differentiating factors were cost and fit to existing infrastructure: Anyconnect and GlobalProtect are designed to work with the Cisco and Palo Alto firewalls respectively, which the Stage 1 selection process has ruled out, while FortiClient works with the FortiGate firewalls the company is buying anyway.

Aaqib's initial suggestion of FortiClient SSL VPN has been upgraded to IPsec VPN: according to Fortinet's own documentation, as of FortiOS 7.6.3 the SSL VPN tunneled web access is deprecated and should be replaced with IPsec. The move to encrypted IPsec connections helps mitigate the risk of web portal compromises which have plagued similar banking industry solutions in the past.

Final Selection: FortiClient IPsec VPN (terminating on the head-office FortiGate)

FortiClient IPsec VPN was selected based on the ability to provide individual, MFA-protected accounts (using the AAA selected in 5.2) for each employee and each of the two external contractors, the ability to check endpoint compliance before tunnel establishment (typically requiring FortiClient EMS licensing, per the vendor [CONFIRM]), and the utilization of the built-in gateway functions that reduce the cost as compared to Cisco and Palo Alto options. It was selected over WireGuard due to the native support of the accountability and MFA requirements. And it was selected over AnyConnect and GlobalProtect due to cost and a single-vendor preference, rather than a technical limitation.

5.2 AAA Solution

Comparative evaluation

Criterion(weight)	Kosgollage: Cisco ISE	Palugaswewa: Aruba Clear Pass	Shaheen: FreeRadius + LDAP/AD	Aaqib: FortiAuthenticator
MFA capability (20)	4	4	2	5
Accounting / audit trail (15)	5	5	3	4
RADIUS/TACACS+ integration with VPN and devices (15)	5	4	4	3
Device profiling / posture for BYOD and contractors (10)	5	5	1	3
Fit with the selected platform (15)	2	2	3	5
Operational burden for the new team (10)	3	3	2	4
Cost (15)	2	2	5	3
Weighted score	74	71	59	79

Of the options considered, Cisco ISE and Aruba ClearPass represent the most capable platforms, with strong user and device profiling and posture assessment functionality, with ISE offering the best fit in an all-Cisco design. Both are also the most expensive and resource heavy options, and neither integrates with the Fortinet firewall and VPN platform chosen in Stage 1. FreeRADIUS with LDAP/AD directory services as proposed by Shaheen is a completely free solution, which has a strong identity store in the directory service but lacks built-in support for multifactor authentication, and would leave the organization without a supported authentication platform, on which they have no experience; it represents the most cost-effective option in the short term. FortiAuthenticator offers RADIUS authentication with multifactor support in the form of

FortiTokens and full accounting in a supported, if more limited, product from the same vendor as the firewall and client endpoints chosen by the group in Stage 1.

The group feels that the choice of FortiAuthenticator represents the best option, as it meets the requirements of multifactor authentication, centralized auditing and accounting, and good integration with the selected infrastructure, while being available in a supported, if smaller scale, solution. The group's concerns with FortiAuthenticator are its comparatively weak device profiling capabilities and integration beyond the ecosystem of Fortinet products, which is a disadvantage over ISE and Aruba ClearPass, but these are not significant to the requirements of Northbridge, which seek to impose individual accountability (via multifactor authentication) and auditing, rather than wide-scale endpoint control.

Final Selection: FortiAuthenticator with FortiToken MFA

FortiAuthenticator was selected due to its ability to completely address the two weaknesses in the scenario described in the question – local per-device accounts and no MFA – at a lower cost than ISE or ClearPass, and due to one vendor and management model shared with the VPN and firewalls. It was selected over free RADIUS because Northbridge should not be reliant on an unsupported platform for its core authentication control, and over ISE and ClearPass primarily for reasons of cost and platform. User licenses should be sized to about 450 staff plus contractors

5.3 Secure Network Architecture

Comparative Evaluation

Criterion (weight)	Kosgollage: Hub-and-spoke with branch firewalls	Palugaswewa: SD-WAN with NGFW zones	Shaheen: Function-based micro-segmentation	Aaqib: Three-tier HQ + router ZBFW at branches
Branch-level ransomware containment (25)	5	5	5	3
Protection of core banking, DMZ and partner zone at HQ (20)	4	4	5	5
Cost (20)	2	1	3	4
Operational complexity (15)	3	3	1	3
Fit with Northbridge's maturity (10)	4	2	1	4
Central policy with the selected AAA (10)	5	4	3	3

Weighted score	76	66	68	74

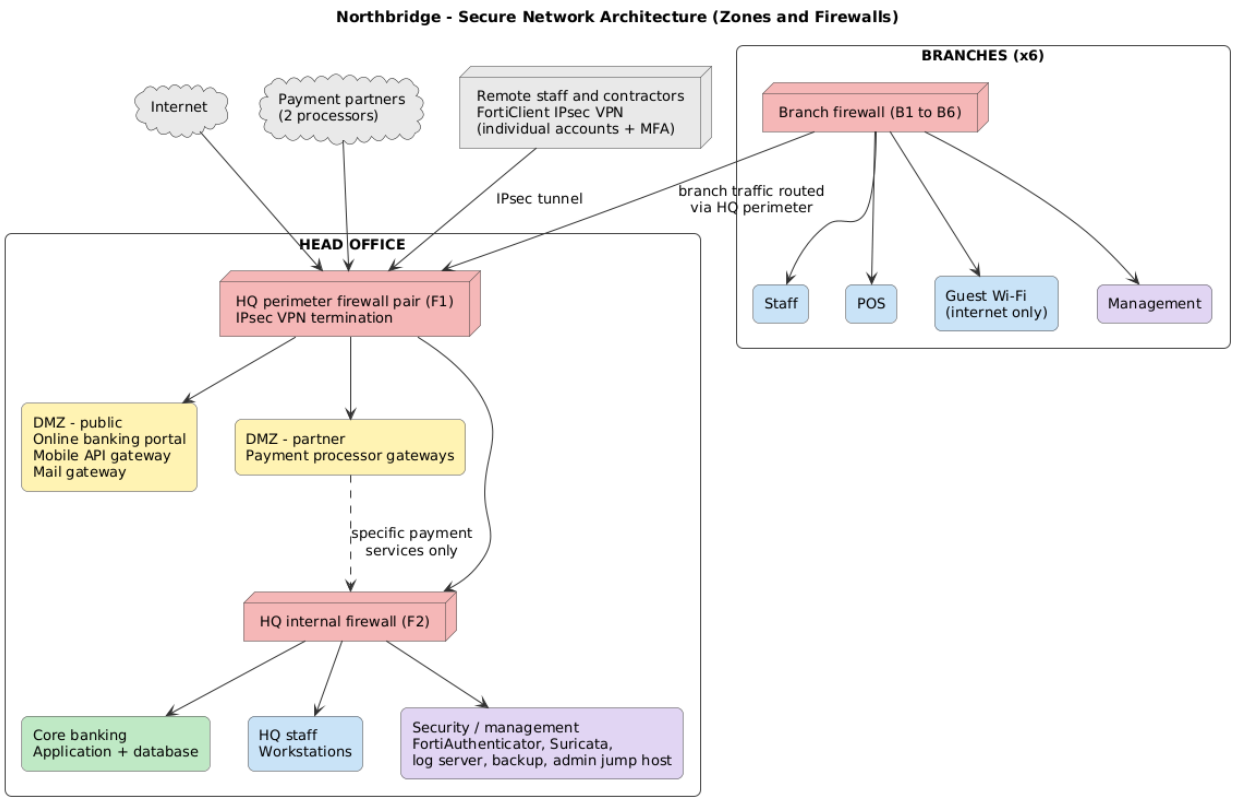
(Kosgollage's cost score of 2 reflects his Cisco firewall hardware; implementing the same design on the lower-cost platform from Stage 1 raises it.)

All four proposals shift Northbridge away from its flat network and address the problem of ransomware-from-a-branch pattern (T5) to various degrees. The most granular is Shaheen's micro-segmentation, which depends on mature identity and network access control for dynamic segment assignment, making it a later-phase goal; its function-based zone naming (staff, POS, guest) is adopted now. Palugaswewa's SD-WAN adds a costly subscription overlay on branch links the scenario doesn't say need to be replaced. Aaqib's three-tier head-office design is the strongest and cheapest head-office model and is adopted for the head-office layer. His router-based filtering at the branches is the weakest match for the scenario's warning that compromises start at a branch workstation, since a router cannot provide the same zone enforcement or inspection as a firewall; it remains a fallback for lower-risk branches if budget is cut. Kosgollage's branch-firewall hub-and-spoke model provides the best containment at the point of origin.

Final Selection: Hub-and-spoke architecture with branch-level firewalls (Kosgollage), with a three-tier zoned head office (Aaqib) and function-based zone naming (Shaheen), built on FortiGate firewalls

The selected design places a FortiGate firewall at each of the six branches, a pair at the head-office perimeter and an internal firewall in front of the core banking, with traffic from the branches to head-office systems and to the Internet routed through the head-office perimeter [CONFIRM]. This gives containment at the branch (C1), inspection at one central point (supporting C9), and a dedicated partner zone for the two payment processors (T7). Smaller branch-class firewall models should be specified to hold cost down.

Zones and firewalls



5.4 IDS / IPS Solution

Comparative Evaluation

Criterion (weight)	Kosgollage: Cisco Secure IPS	Palugaswewa: Palo Alto Advanced Threat Prevention	Shaheen: Zeek	Aaqib: Suricata
Inline prevention (25)	5	5	1	4
Detection quality / threat intelligence (15)	4	4	3	4
Fit with the selected platform (10)	2	2	2	3
Tuning / maintenance burden for the new team (15)	4	4	2	2
Cost (25)	2	1	5	5
Logging / visibility (10)	4	4	5	4

Weighted score	71	66	59	77

Zeek is a passive monitor, meaning that it provides visibility but lacks the ability to prevent, so it does not answer the problem statement for Northbridge being blind to reconnaissance or active probing before visible effects occur. It is also noted as a viable option for the later stages of development due to its logging capabilities that tie into the central logs. Cisco Secure IPS and Palo Alto Advanced Threat Prevention are strong choices inline, but both are attached to the firewall platforms that Northbridge did not choose to adopt, and both carry the highest possible subscription prices. Suricata is free, supports prevention in-line, and has community support with good rule sets, making it the best value.

The group acknowledges the risk of Suricata, which is that the rules and tuning are up to the operators and that they have limited experience, but it addresses that danger in a few ways. It is only placed inline at the main office perimeter and internal boundary and not at the perimeters of the branch offices or partners, reducing the risk of mistakes. It is turned off in prevention mode until the team understands the alert flood and only blocks what needs to be stopped. It is also updated automatically through the default rule set feeds, and its alerts are sent to the C9 central logging system, which are then reviewed rather than acted on immediately. If the team proves unable to sustain the required attention to the Suricata alerts, the built-in IPS subscription on the FortiGate firewalls can be used as a fallback, as it is a supported product.

Final Selection: Suricata (open-source IDS/IPS), deployed at head office and integrated with centralized logging (C9)

Suricata has been selected due to it meets the prevention requirement at no licensing cost and was selected over Zeek as the scenario calls for prevention and not simply visibility, and over Cisco Secure IPS and Palo Alto Advanced Threat Prevention which require the platform and the recurring cost the group avoided in stage 1. Suricata only inspects traffic that crosses head office and therefore east-west traffic within a single branch is not inspected which is an accepted residual risk, covered by the branch zone rules (C1), Layer-2 controls (C3–C5) and the patch programme (C6).

5.5 Summary of group selections

Area	Selected	Score	Runner up	Adopted from other proposals
VPN	FortiClient IPsec VPN	84	Cisco Secure client	Endpoint – compliance requirement (Kosgollage, Aaqib)
AAA	FortiAuthenticator with FortiToken MFA	79	Cisco ISE	Directory – backed identity store (Shaheen);

				FreeRadius kept as budget fallback
Architecture	Hub and spoke with branch firewalls on Fortigate	76	Aaqib's three tier + router ZBFW	Aaqib's three tier head office; Shaheen's function based zones ; micro-segmentation deferred
IDS/IPS	Suricata	77	Cisco Secure IPS	Zeek as later – phase complement (Shaheen)

6. Network Hardening Configurations

Member	Plan linked config	Free choice config
Aaqib	Zone based firewall	ACL for inter VLAN filtering
Palugaswewa K I K I B	VLAN segmentation	SSH Configuration for Secure Device Management
Kosgollage S R	Port security	DHCP Snooping
Shaheen	AAA configuration	VPN (Site to site IPsec)

Kosgollage S R - Plan linked Configuration - Port security

Restricts which devices (by MAC address) can connect to a switch port, preventing rogue devices or unauthorized personal devices from communicating on the network. This directly addresses **T5** (rogue device via unlocked branch cabinets) and **T8** (unmanaged personal/BYOD devices).

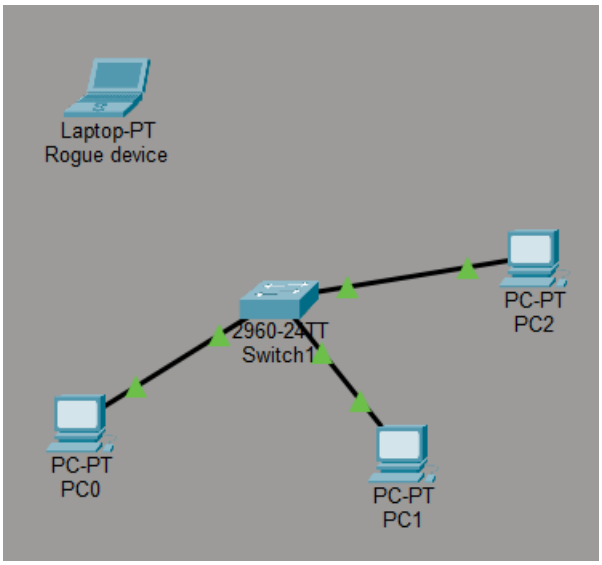


Figure 1.Initial configuration

Configuration command

Switch#configure terminal.
Switch(config)#interface fastEthernet0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 1
Switch(config-if)#switchport port-security mac-address sticky

Switch(config-if)#switchport port-security violation shutdown
Switch(config-if)#exit

```
Switch#show port-security interface fastEthernet0/1
Port Security              : Enabled
Port Status                : Secure-up
Violation Mode             : Shutdown
Aging Time                 : 0 mins
Aging Type                 : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses      : 1
Total MAC Addresses        : 1
Configured MAC Addresses   : 0
Sticky MAC Addresses       : 1
Last Source Address:Vlan   : 0001.C71A.E4C2:1
Security Violation Count   : 0

Switch#
```

Figure 2.Configuration enabled - Port security

```
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/1, changed state to down
%PM-4-ERR_DISABLE: psecure-violation error detected on Fa0/1, putting Fa0/1 in err-disable state.
%PORT_SECURITY-2-PSECURE_VIOLATION: Security violation occurred, caused by MAC address
0001.9696.30A1 on port FastEthernet0/1.
```

Figure 3. Switch shut down when rogue PC connects to the secured port

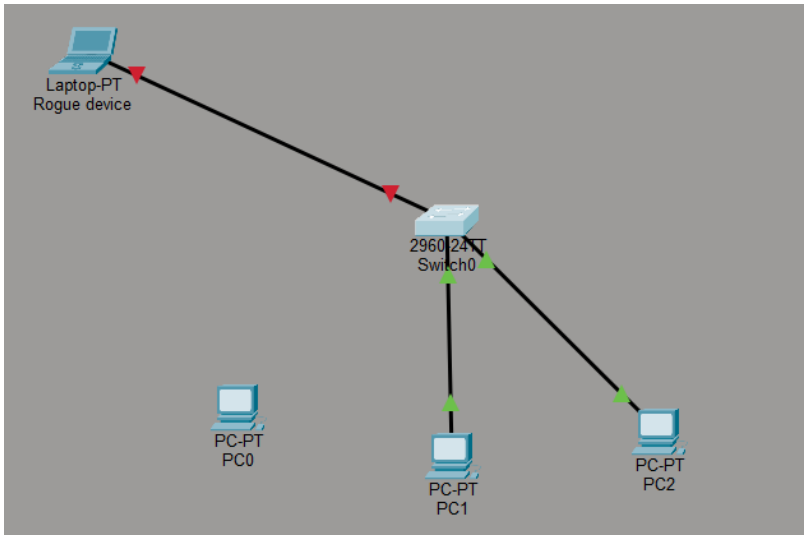


Figure 4. Rogue PC fails when connected to a secured port

Kosgollage S R - DHCP Snooping – Free choice configuration

```
Switch>enable
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#ip dhcp snooping
Switch(config)#ip dhcp snooping vlan 1
Switch(config)#interface fastEthernet0/2
Switch(config-if)#ip dhcp snooping trust
Switch(config-if)#exit
Switch(config)#interface fastEthernet0/3
Switch(config-if)#ip dhcp snooping limit rate 10
Switch(config-if)#exit
Switch(config)#exit
Switch#
```

```
DHCP snooping is configured on following VLANs:
1
Insertion of option 82 is enabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                Trusted    Rate limit (pps)
------------------------ -------    ----------------
FastEthernet0/2          yes        unlimited
FastEthernet0/3          no         10
Switch#
```

Figure 5. Switch trusts legitimate server

```
Switch#show ip dhcp snooping binding
MacAddress          IpAddress        Lease(sec)  Type           VLAN  Interface
------------------  ---------------  ----------  -------------  ----  --------------------
00:50:0F:E4:5A:3B   192.168.1.20     86400       dhcp-snooping  1     FastEthernet0/1
Total number of bindings: 1
```

Figure 6. PC MAC address securely bindiing its new IP address

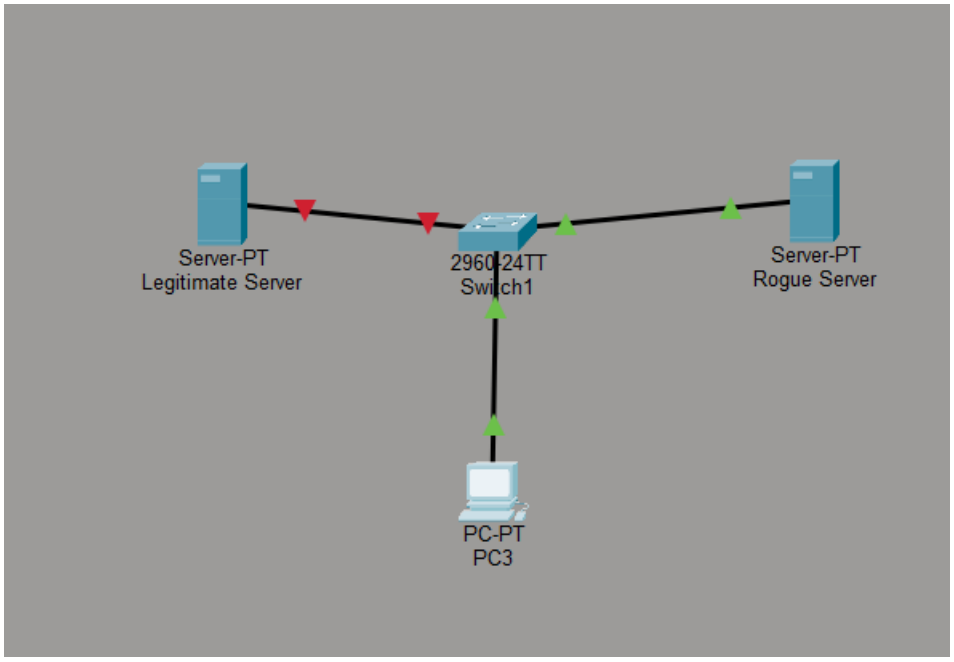


Figure 7. Testing the rogue server.

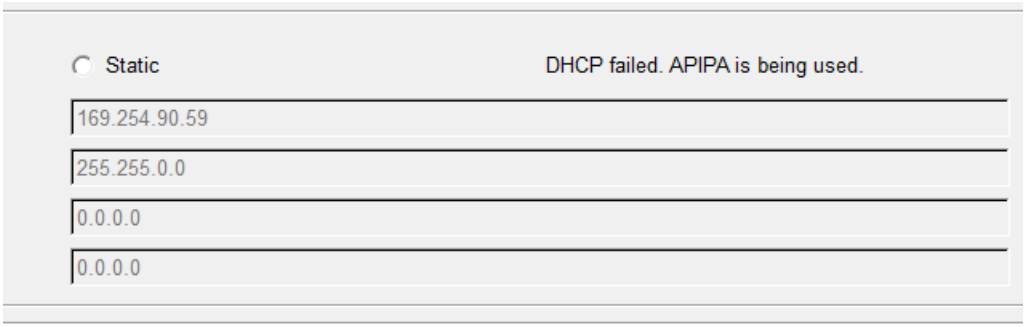


Figure 8. DHCP snooping successful as rogue server failed

```
Switch#show ip dhcp snooping binding
MacAddress          IpAddress        Lease(sec)  Type           VLAN  Interface
------------------  ---------------  ----------  -------------  ----  --------------------
00:50:0F:E4:5A:3B   192.168.1.20     86400       dhcp-snooping  1     FastEthernet0/1
Total number of bindings: 1
Switch#
```

Figure 9. Legitimate server working again and binds with the PC

Aaqib – Planed link – Zone based firewall

Topology diagram

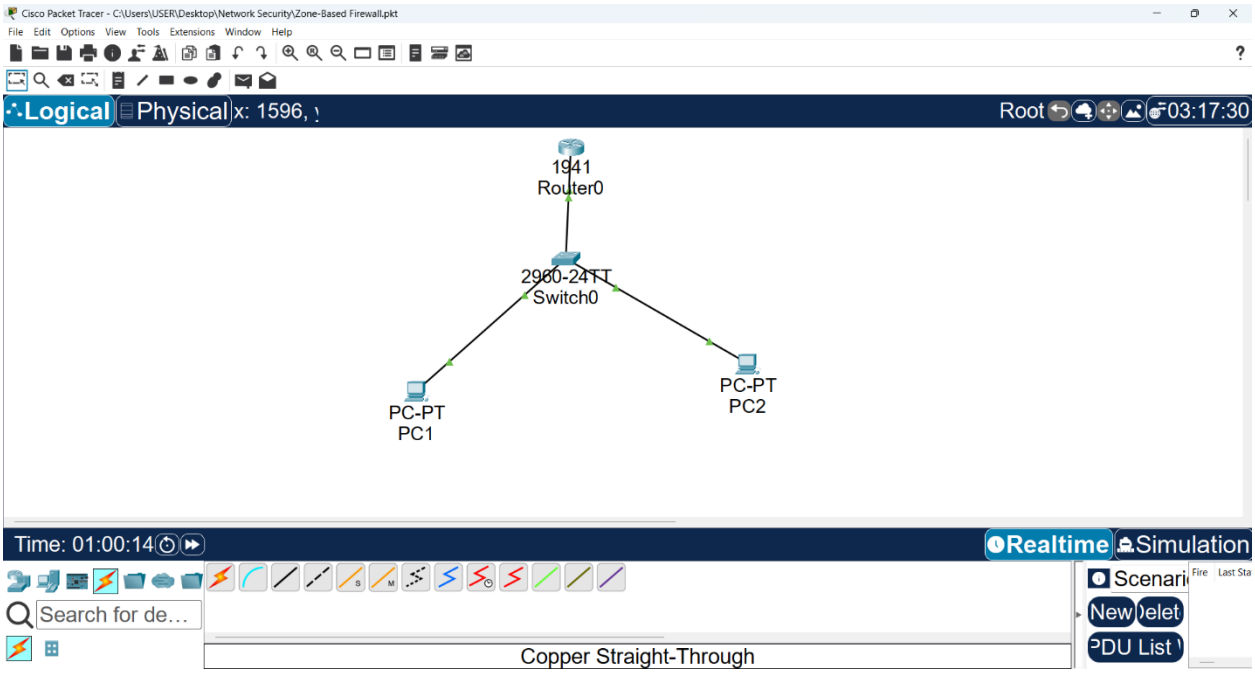


Figure 10. Network topology — Router0, Switch0, PC1 (STAFF) and PC2 (GUEST_POS) connected via trunk link.

PC1 IP config

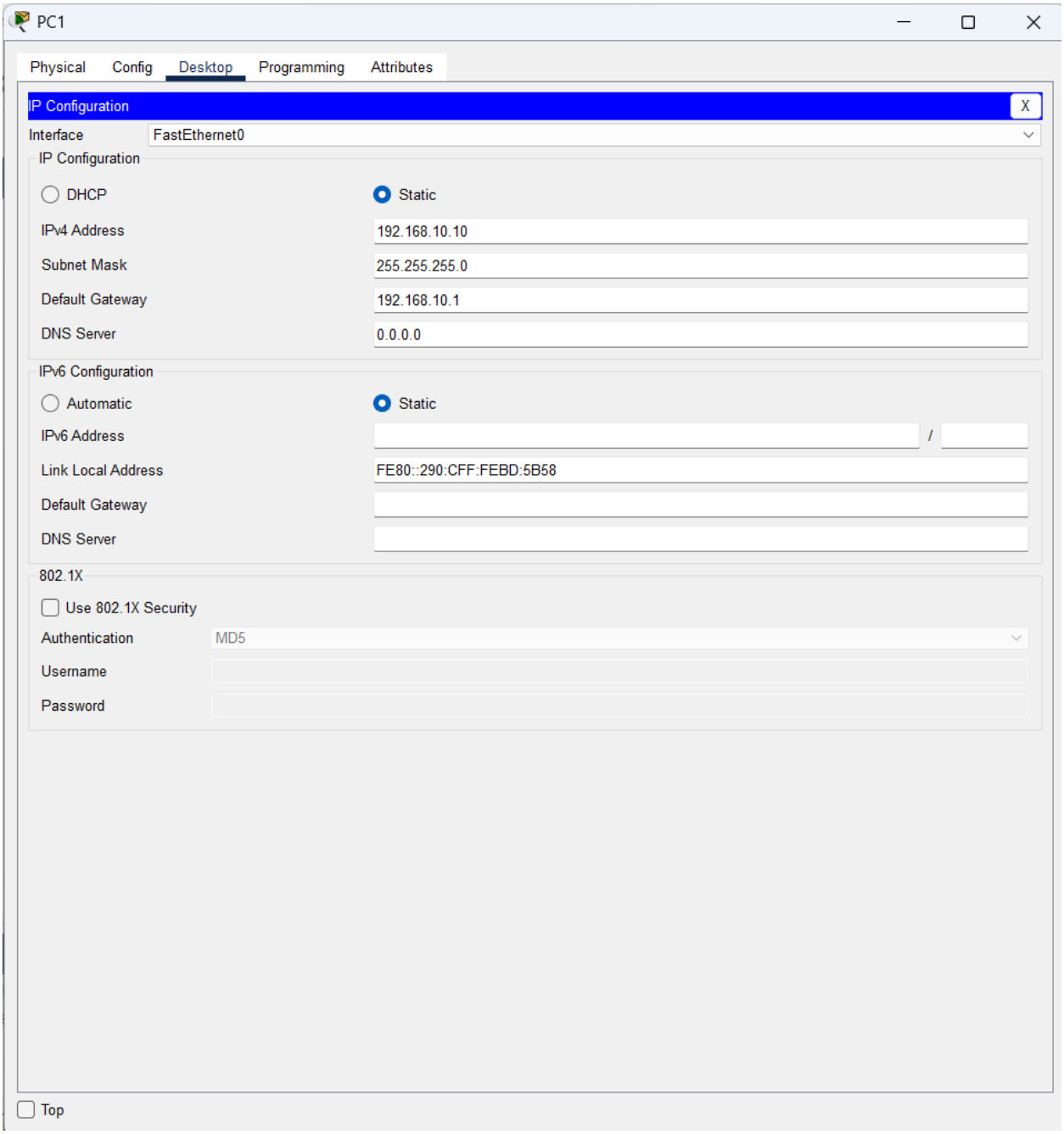


Figure 11. PC1 (STAFF) static IP configuration — 192.168.10.10/24, gateway 192.168.10.1.

PC1 ping sequence

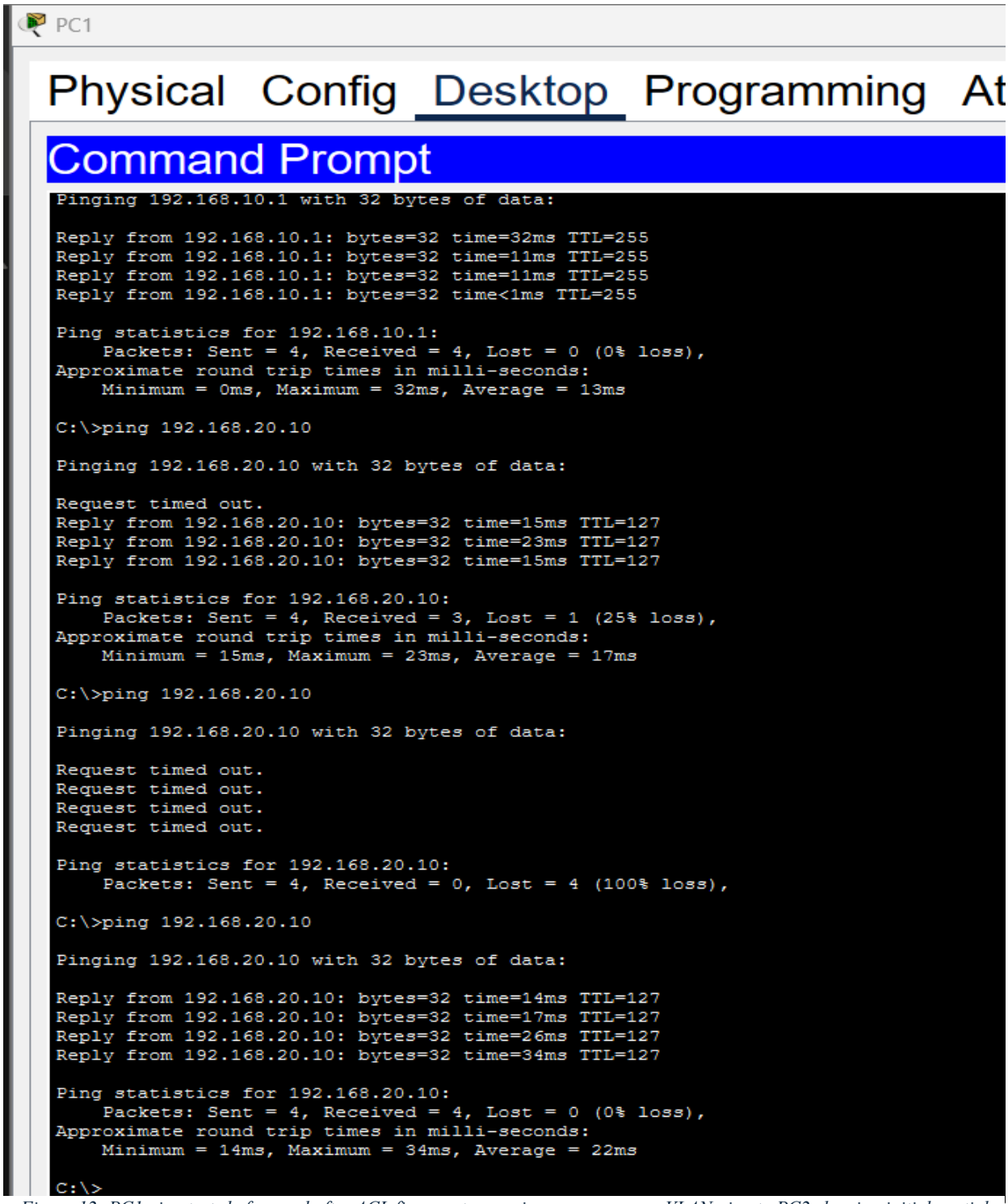


Figure 12: PC1 ping tests before and after ACL fix — gateway ping success, cross-VLAN ping to PC2 showing initial partial loss (ARP delay) then 100% success after adding the echo-reply permit rule.

PC2 IP config

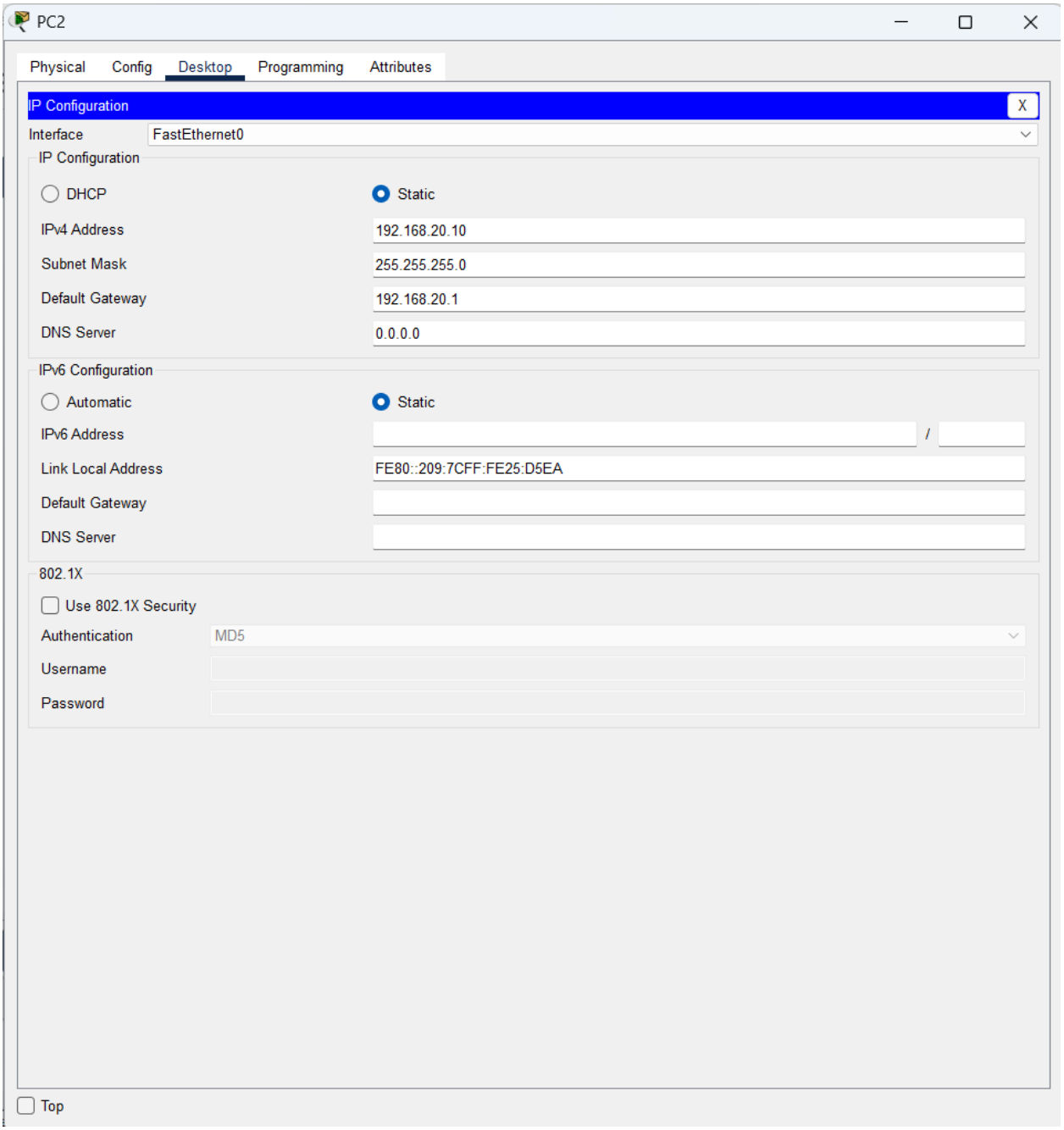


Figure 13: PC2 (GUEST_POS) static IP configuration — 192.168.20.10/24, gateway 192.168.20.1.

PC2 ping blocked (2 attempts)

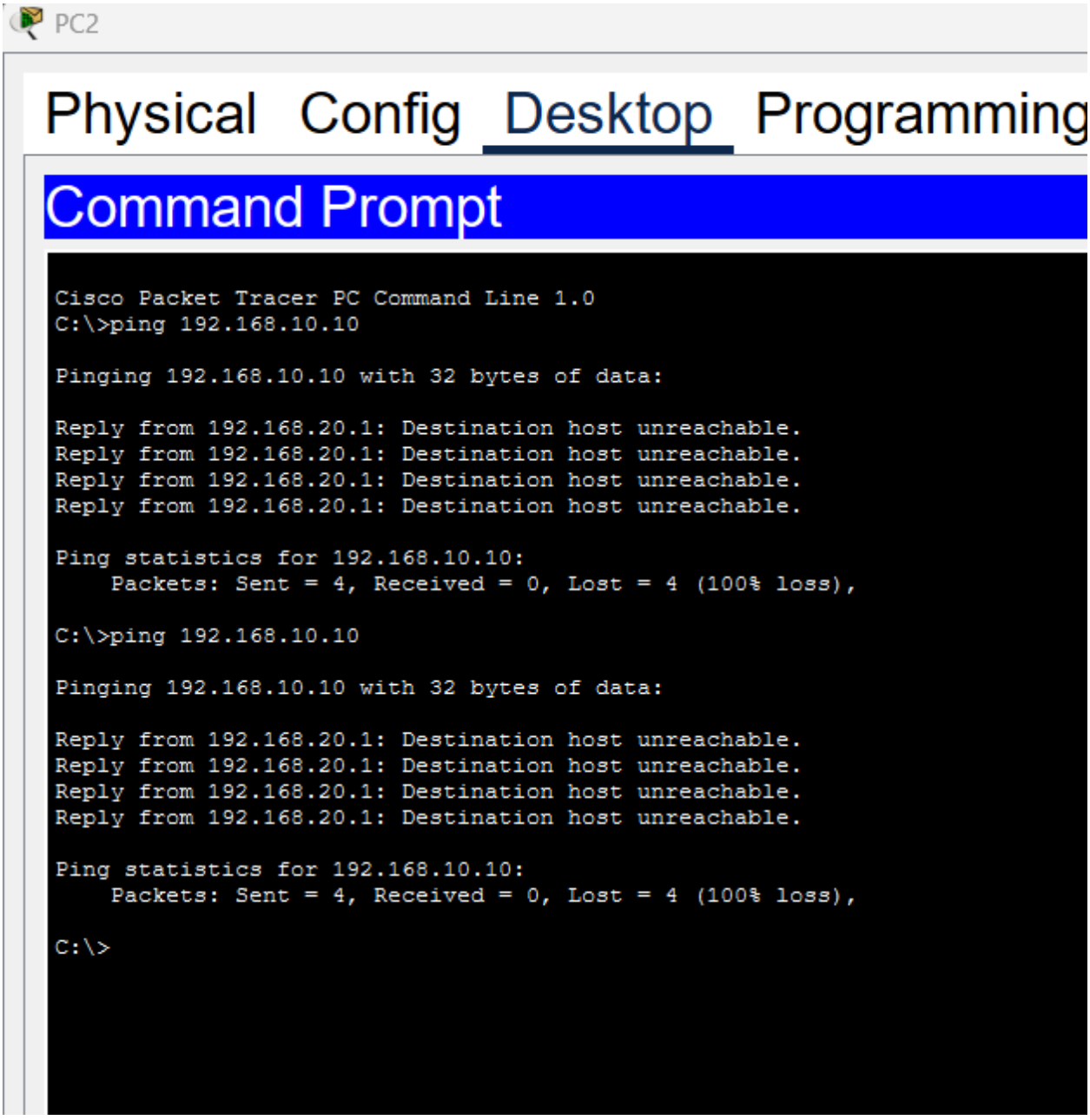


Figure 14. PC2 → PC1 ping blocked by ACL 110 -"Destination host unreachable", confirming GUEST-to-STAFF traffic is denied.

PC2 ping blocked (1 attempt)

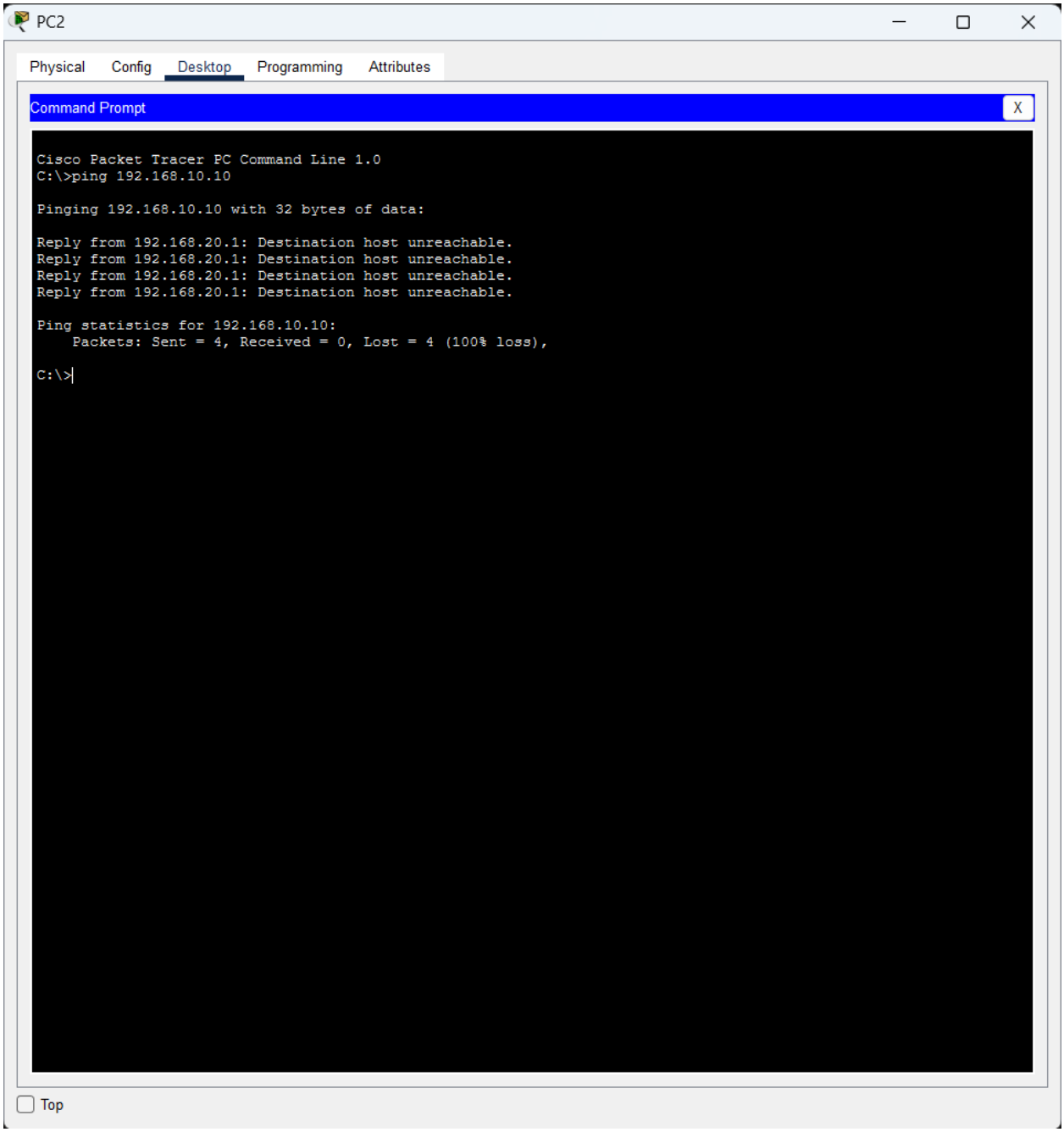


Figure 15. Repeat verification of PC2 → PC1 ping block after saving the configuration, confirming the ACL rule persists.

Router boot screen (part 1)

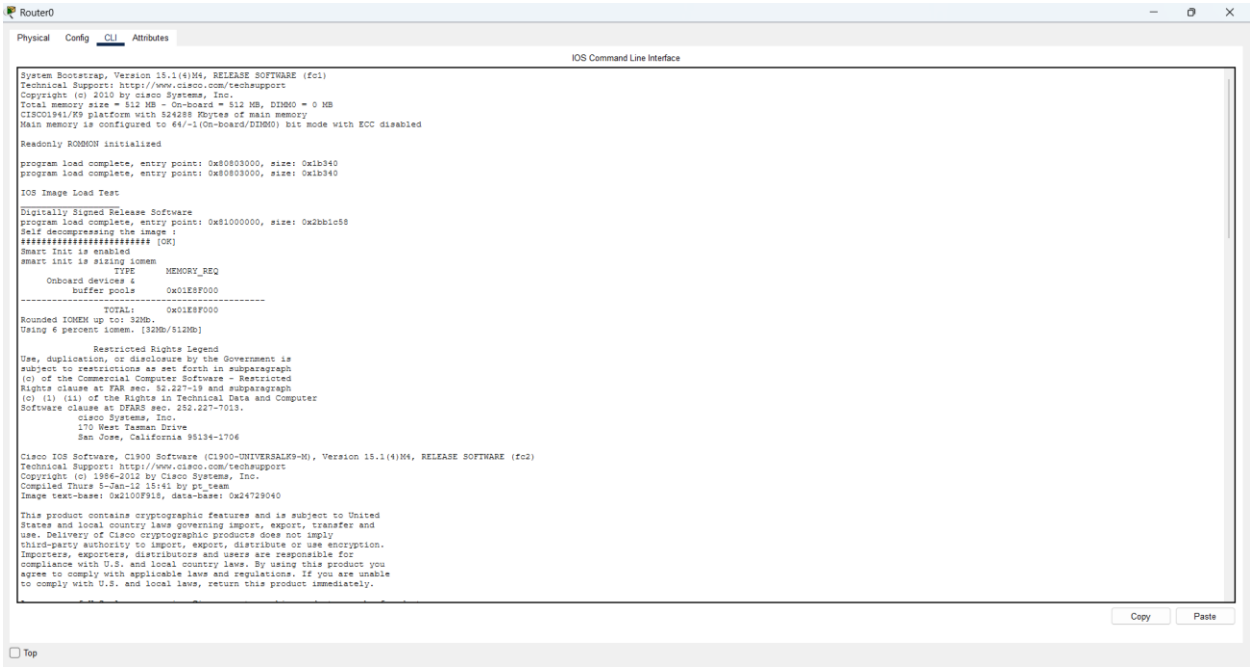


Figure 16. Router0 IOS bootup sequence

Router boot + running-config start

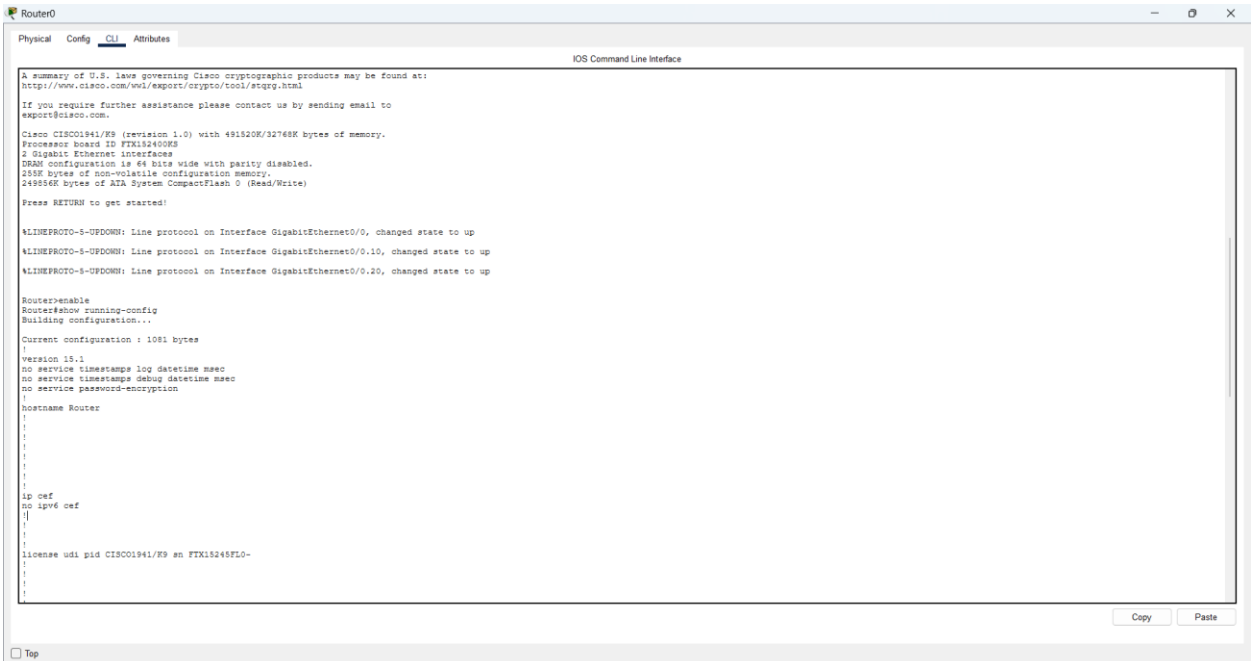


Figure 17: Router0 interfaces coming up (Gig0/0, Gig0/0.10, Gig0/0.20) and the start of the show running-config output.

Router running-config (interfaces + ACL)

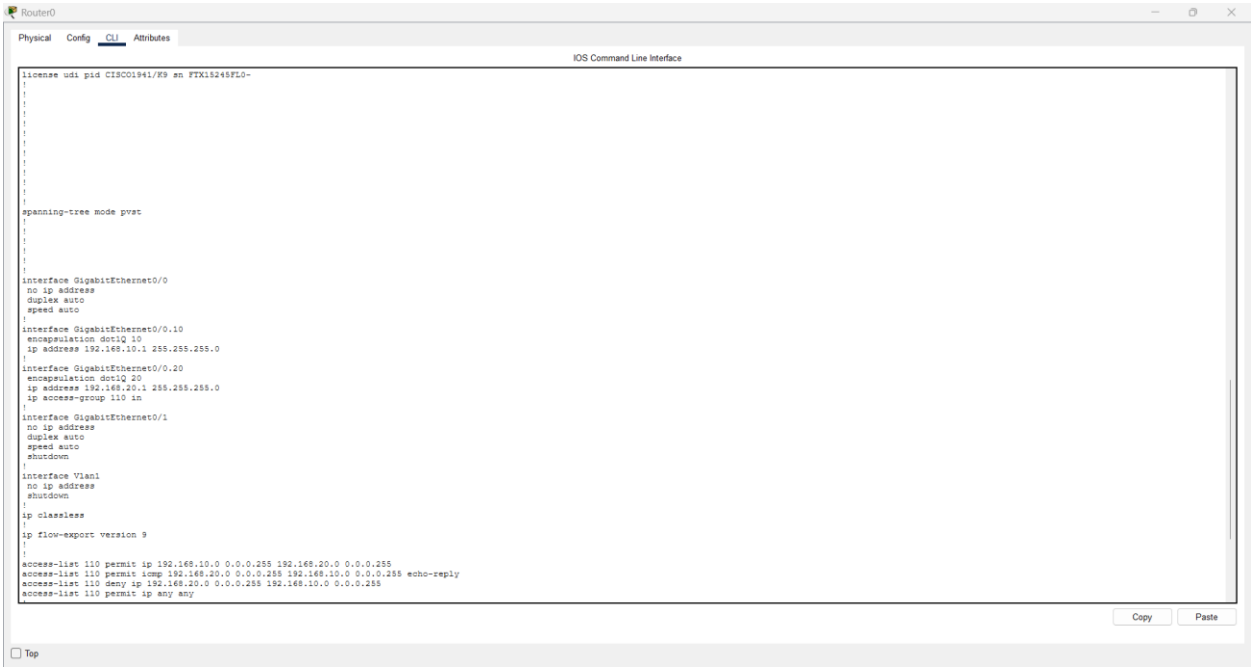


Figure 18. Router0 running-config showing sub interface configuration (encapsulation, IP addressing) and ACL 110 applied inbound on Gig0/0.20.

Router running-config (ACL + end)

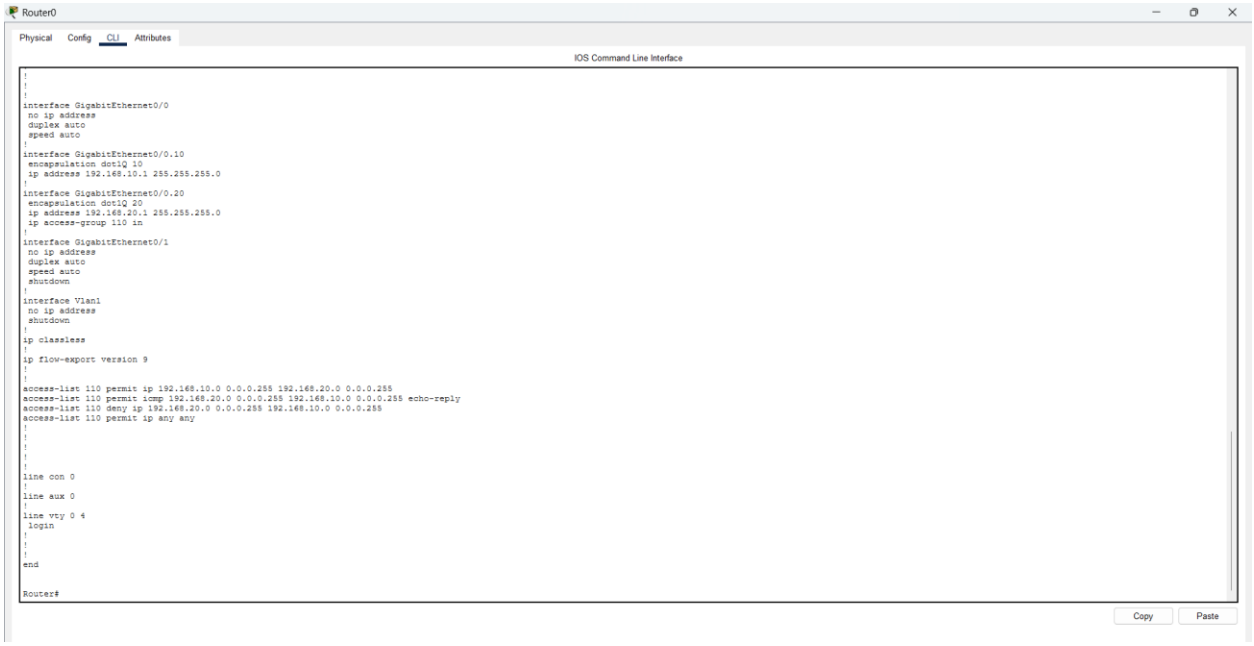


Figure 19. Router0 running config continued, showing the complete ACL 110 rule set and end of configuration.

Switch boot screen (part 1)

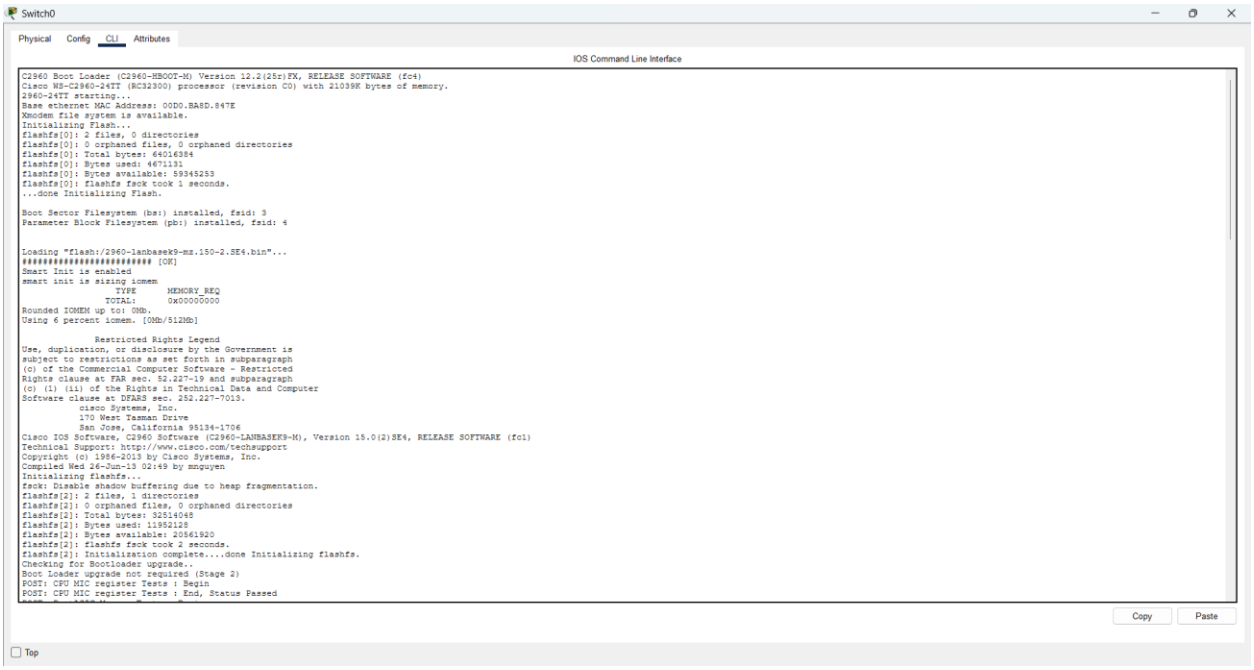


Figure 20. Switch IOS bootloader and flash initialization sequence

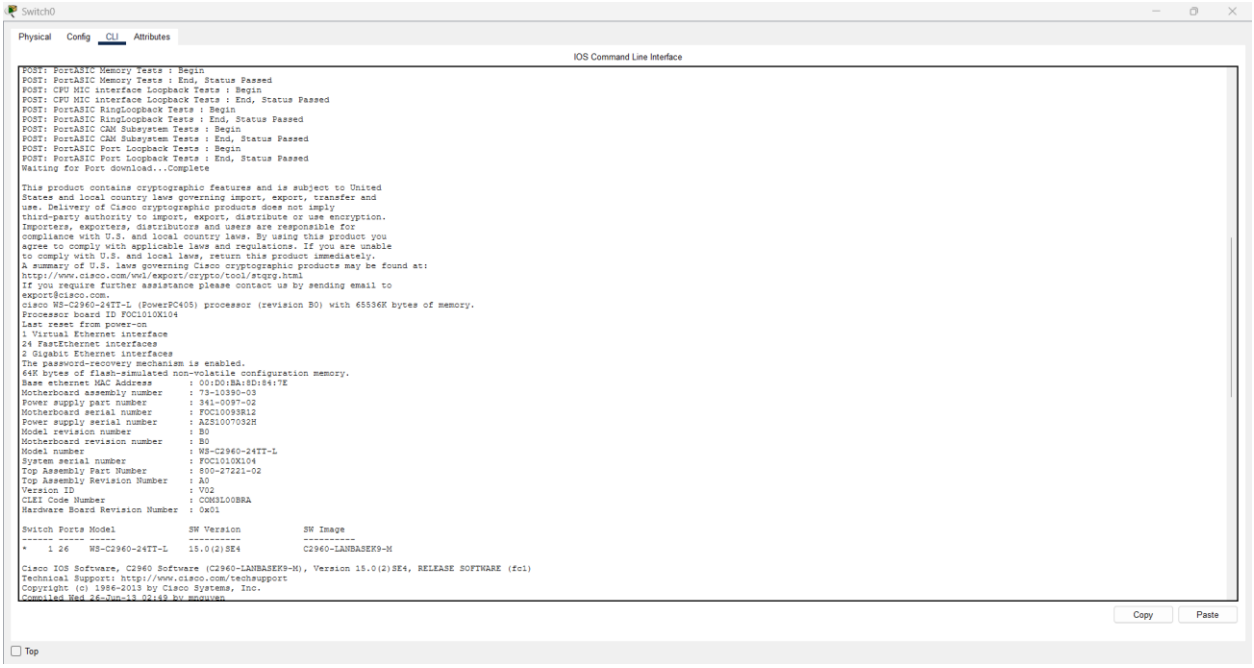


Figure 21: Switch0 hardware details and IOS software version information.

Switch boot screen (part 2)

Switch VLAN brief

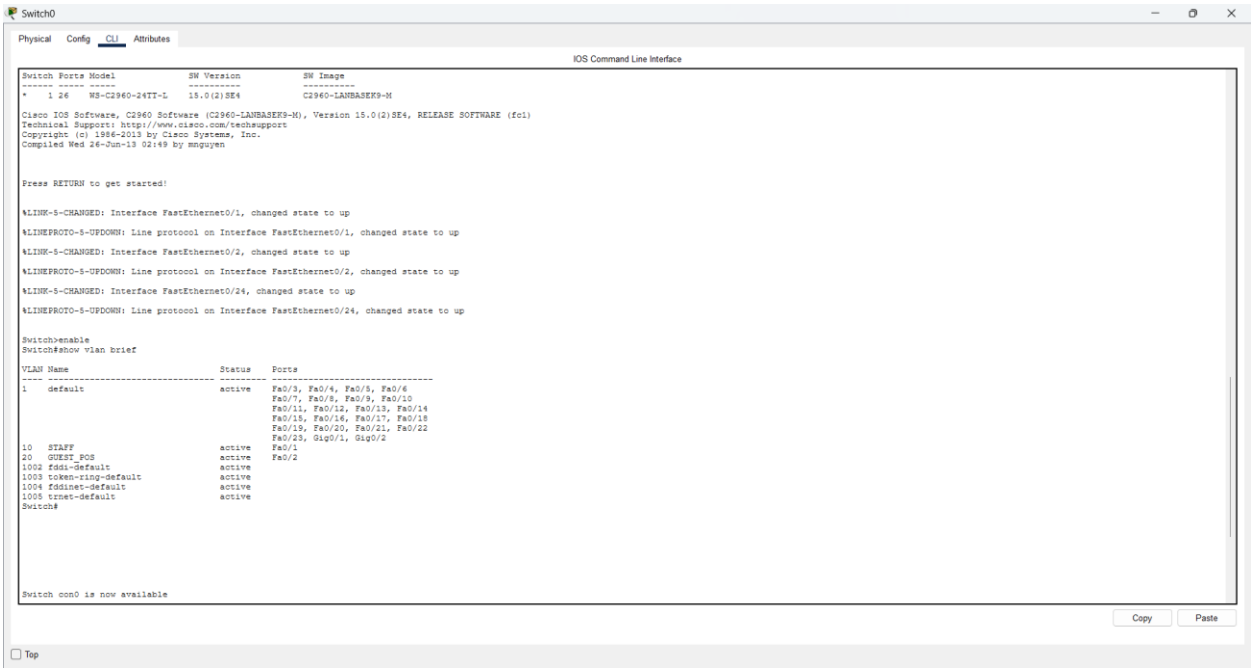


Figure 22: Switch0 show vlan brief output confirming VLAN 10 (STAFF) on Fa0/1 and VLAN 20 (GUEST_POS) on Fa0/2.

Switch VLAN brief continued

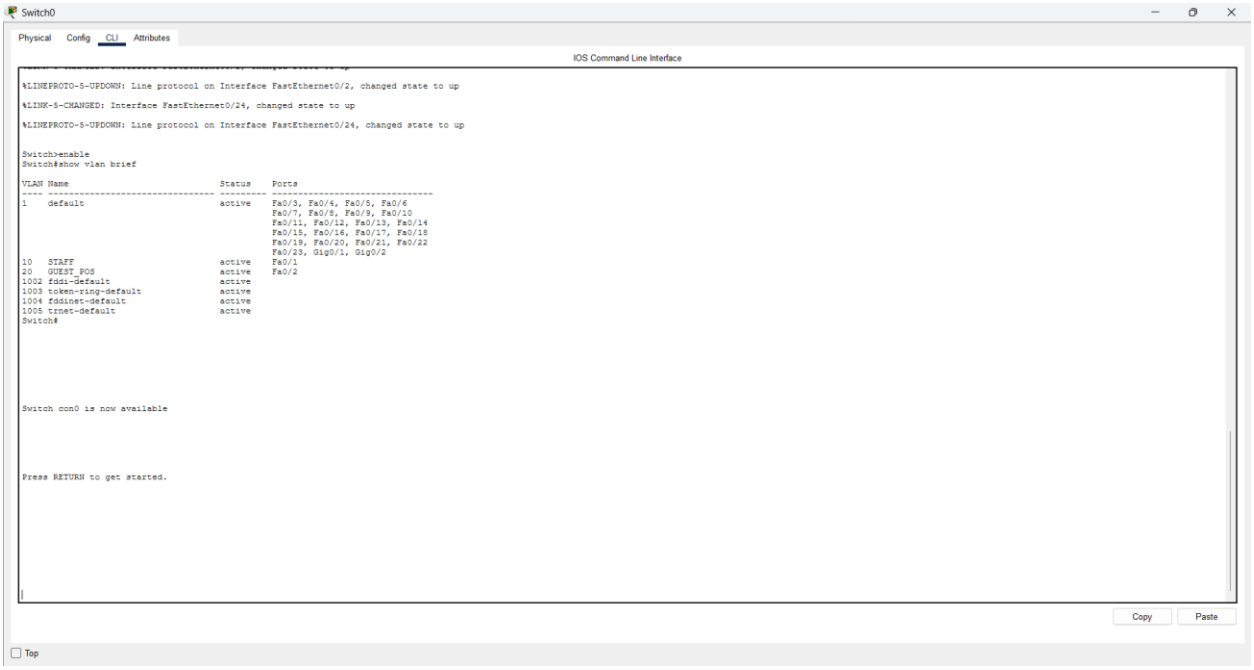


Figure 23: Switch0 configuration confirmed persistent after console reconnection.

Config 1 Report

This configuration implements network segmentation between the STAFF VLAN (192.168.10.0/24) and the GUEST/POS VLAN (192.168.20.0/24) using an Extended ACL on the router's GUEST subinterface. It allows STAFF-initiated traffic to reach GUEST/POS systems while blocking any GUEST/POS-initiated connection into the STAFF network, only permitting ICMP echo-replies to support legitimate return traffic from staff-initiated pings.

Threat addressed: This directly mitigates the ransomware-spread threat (T1) and the unpatched-workstation lateral-movement threat (T3) identified in the group's threat modeling - by preventing a compromised device on the guest/POS/branch segment from initiating any connection into the staff/head-office network, containing the blast radius of a compromise to the segment where it originated.

Note on implementation: Packet Tracer's simulated IOS does not support native Zone-Based Policy Firewall commands (zone security/zone-pair). The same directional segmentation logic proposed in the Layered Security Plan (Control C1) was therefore implemented using an equivalent Extended ACL, demonstrating the same security outcome within the tool's capabilities.

Commands

```
interface GigabitEthernet0/0.20
 encapsulation dot1Q 20
 ip address 192.168.20.1 255.255.255.0
ip access-group 110 in
!
access-list 110 permit ip 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255
access-list 110 permit icmp 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255 echo-reply
access-list 110 deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
access-list 110 permit ip any any
Router ACL 120 creation + show access-lists
```

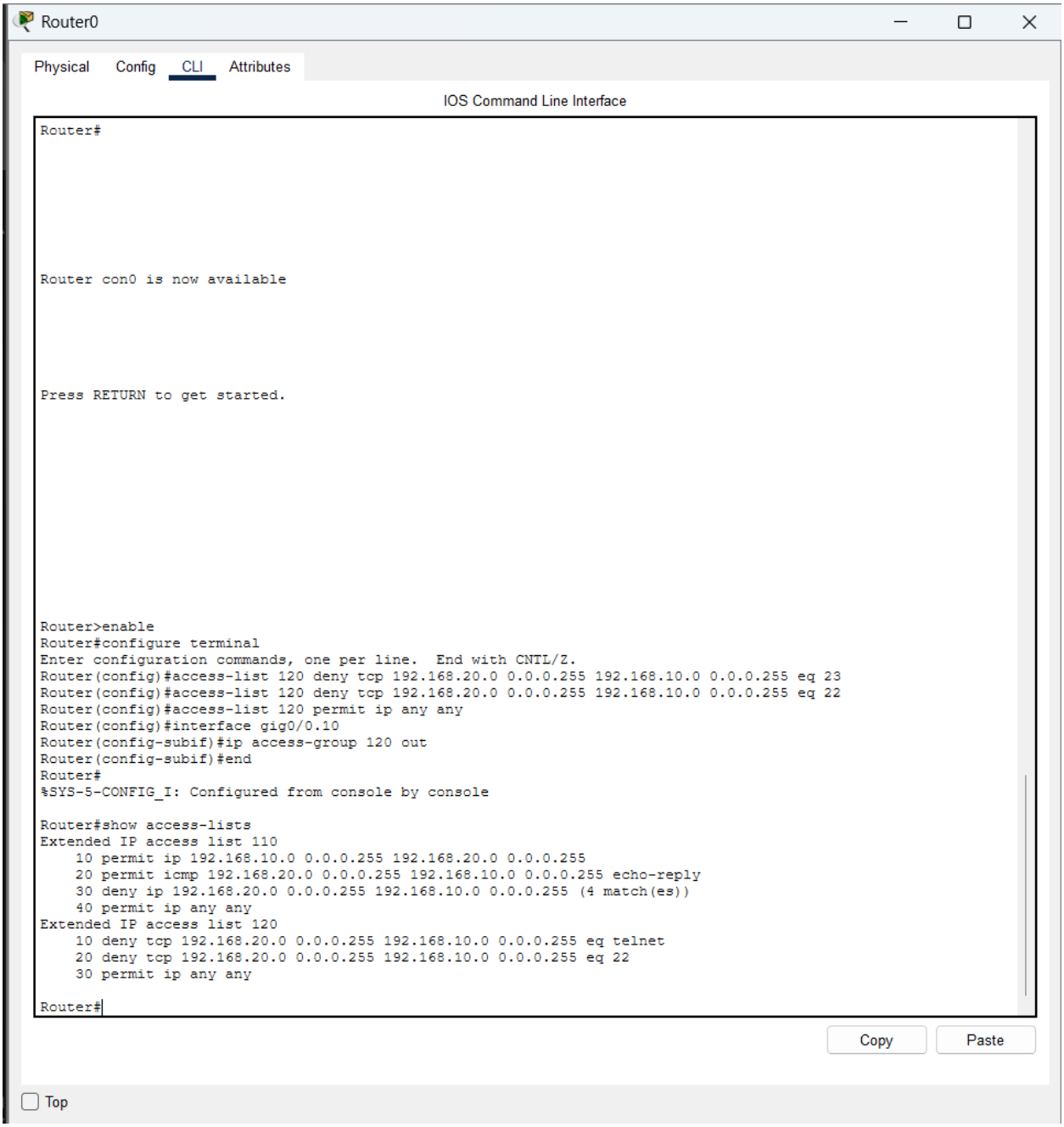


Figure 24. Router0 ACL 120 creation (Telnet/SSH deny rules) applied outbound on Gig0/0.10, with show access-lists confirming both ACL 110 and ACL 120

Router ACL 120 + VTY telnet setup

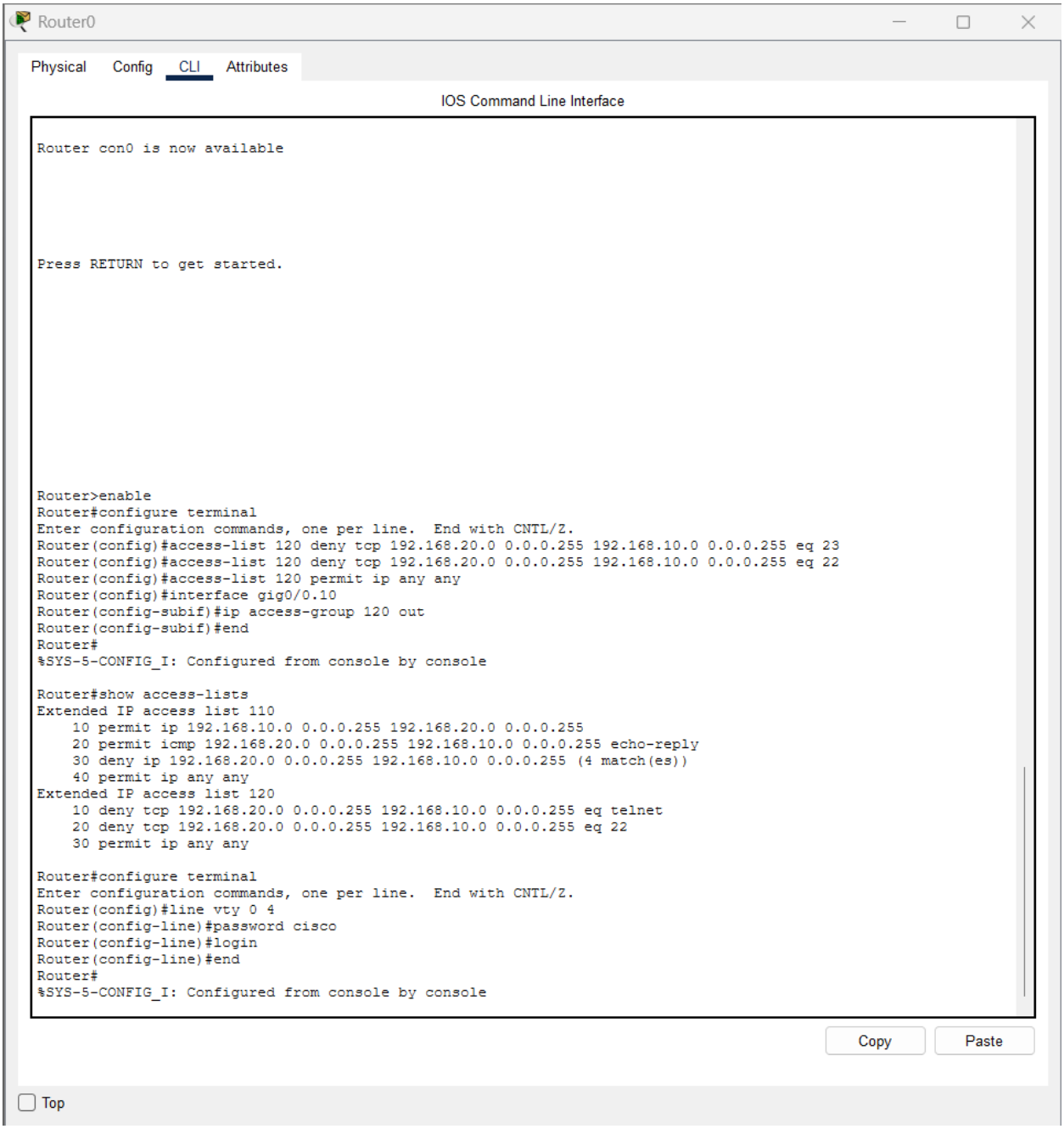


Figure 25. Router0 VTY lines configured with a password to enable Telnet access for verification testing.

PC2 telnet blocked

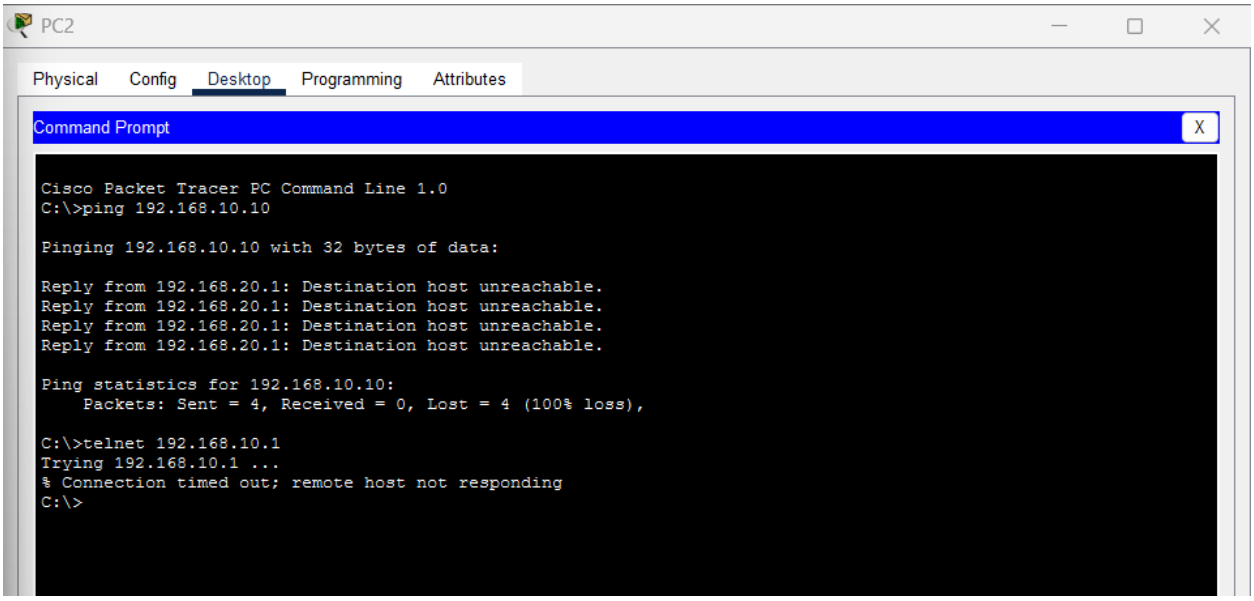


Figure 26: PC2 (GUEST) → Telnet to 192.168.10.1 "Connection timed out", confirming ACL 120 blocks GUEST-initiated Telnet.

PC1 telnet success

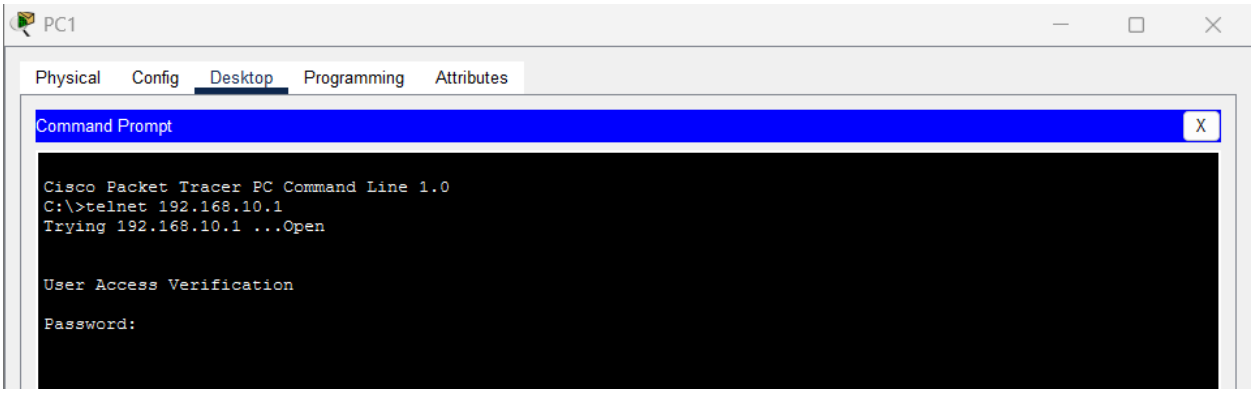


Figure 27. PC1 (STAFF) → Telnet to 192.168.10.1 — connection opens and reaches the password prompt, confirming legitimate STAFF access is unaffected.

This configuration implements a protocol-specific Extended ACL (120) that blocks Telnet (port 23) and SSH (port 22) management-protocol traffic originating from the GUEST/POS VLAN (192.168.20.0/24) toward the STAFF VLAN (192.168.10.0/24), while permitting legitimate STAFF-initiated remote management access.

Real-world problem solved: Prevents an unauthorized or compromised device on the guest/POS segment from attempting to remotely administer staff-side network infrastructure or devices via Telnet/SSH, providing a targeted, protocol-level layer of defense that operates independently of the broader VLAN segmentation control (Config 1/C1). Even if segmentation

policy changes for other traffic types, this control continues to block unauthorized management-protocol access specifically.

```
access-list 120 deny tcp 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255 eq 23
access-list 120 deny tcp 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255 eq 22
access-list 120 permit ip any any
!
interface GigabitEthernet0/0.10
ip access-group 120 out
```

Verification evidence

show access-lists — ACL 120 rules confirmed

PC2 (GUEST) → Telnet 192.168.10.1 → Connection timed out (blocked)

PC1 (STAFF) → Telnet 192.168.10.1 → Open, password prompt (allowed)

Shaheen M F M - Plan-Linked Configuration – AAA Configuration (C2)

Free-Choice Configuration – **VPN Configuration (Site-to-Site IPsec)**

Topology

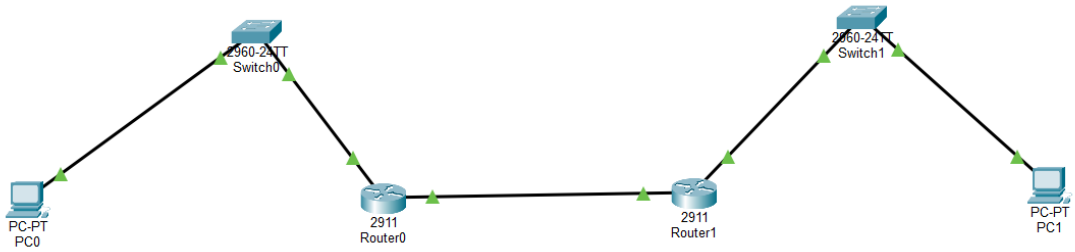


Figure 28

PC 0

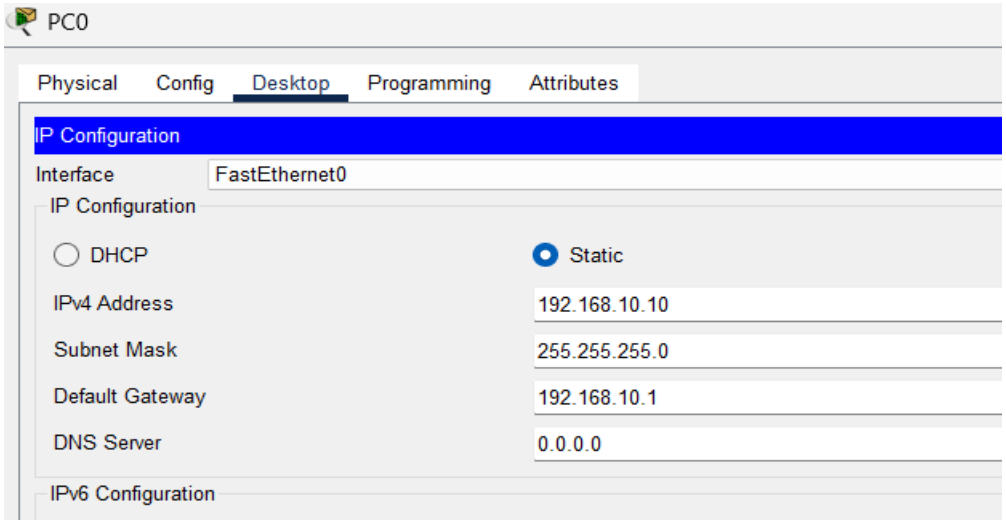


Figure 29. PC0

PC1

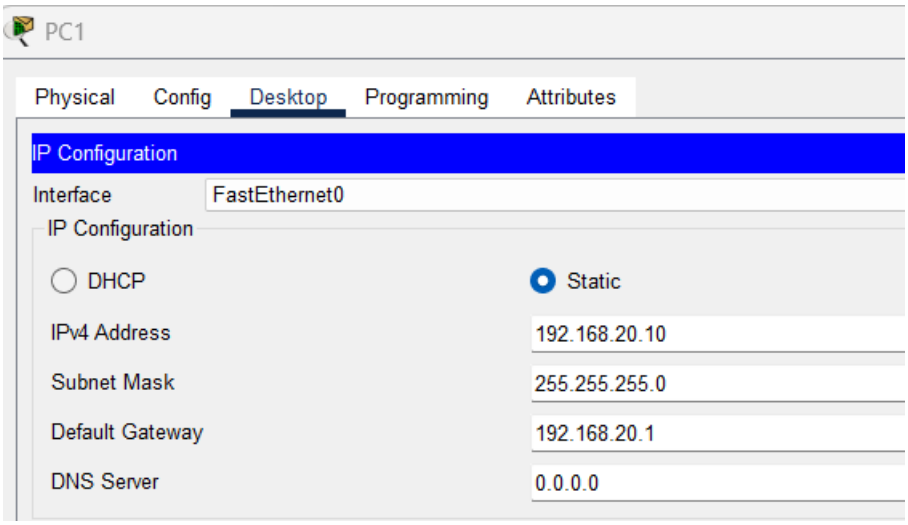


Figure 30

Router0

```
        --- System Configuration Dialog ---

Would you like to enter the initial configuration dialog? [yes/no]:
% Please answer 'yes' or 'no'.
Would you like to enter the initial configuration dialog? [yes/no]: no


Press RETURN to get started!



Router>enable
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#interface gigabitEthernet 0/0
Router(config-if)#ip address 192.168.10.1 255.255.255.0
Router(config-if)#no shutdown

Router(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to up
exit
Router(config)#interface gigabitEthernet 0/1
Router(config-if)#ip address 203.0.113.1 255.255.255.252
Router(config-if)#no shutdown

Router(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/1, changed state to up
exit
Router(config)#
%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to up
```

Figure 31

```
Router>enable
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#ip route 192.168.20.0 255.255.255.0 203.0.113.2
Router(config)#end
Router#
%SYS-5-CONFIG_I: Configured from console by console

Router#show ip route
Codes: L - local, C - connected, S - static, R - RIP, M - mobile, B - BGP
       D - EIGRP, EX - EIGRP external, O - OSPF, IA - OSPF inter area
       N1 - OSPF NSSA external type 1, N2 - OSPF NSSA external type 2
       E1 - OSPF external type 1, E2 - OSPF external type 2, E - EGP
       i - IS-IS, L1 - IS-IS level-1, L2 - IS-IS level-2, ia - IS-IS inter area
       * - candidate default, U - per-user static route, o - ODR
       P - periodic downloaded static route

Gateway of last resort is not set

     192.168.10.0/24 is variably subnetted, 2 subnets, 2 masks
C       192.168.10.0/24 is directly connected, GigabitEthernet0/0
L       192.168.10.1/32 is directly connected, GigabitEthernet0/0
S    192.168.20.0/24 [1/0] via 203.0.113.2
     203.0.113.0/24 is variably subnetted, 2 subnets, 2 masks
C       203.0.113.0/30 is directly connected, GigabitEthernet0/1
L       203.0.113.1/32 is directly connected, GigabitEthernet0/1

Router#
```

Figure 32

Router1

```
        --- System Configuration Dialog ---

Would you like to enter the initial configuration dialog? [yes/no]: no


Press RETURN to get started!



Router>enable
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#interface gigabitEthernet 0/0
Router(config-if)#ip address 192.168.20.1 255.255.255.0
Router(config-if)#no shutdown

Router(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to up
exit
Router(config)#interface gigabitEthernet 0/1
Router(config-if)#ip address 203.0.113.2 255.255.255.252
Router(config-if)#no shutdown

Router(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/1, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to up
exit
Router(config)#
```

Figure 33

AAA Configuration (Plan – Linked Config)

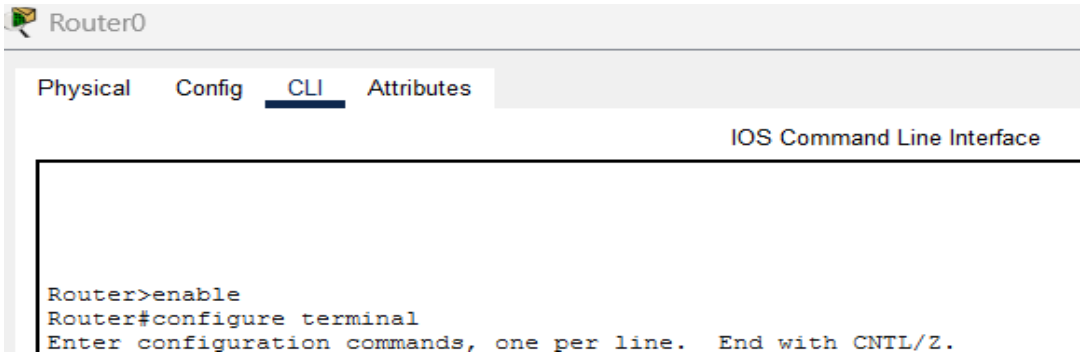


Figure 34

```
Router(config)#username netadmin privilege 15 secret Cisco123!
Router(config)#aaa new-model
Router(config)#aaa authentication login NB-AAA local
Router(config)#ip domain-name northbridge.local
Router(config)#crypto key generate rsa
```

Figure 35

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#hostname R-HQ
R-HQ(config)#crypto key generate rsa
The name for the keys will be: R-HQ.northbridge.local
Choose the size of the key modulus in the range of 360 to 4096 for your
  General Purpose Keys. Choosing a key modulus greater than 512 may take
  a few minutes.

How many bits in the modulus [512]: 1024
% Generating 1024 bit RSA keys, keys will be non-exportable...[OK]

R-HQ(config)#line vty 0 4
*Mar 1 2:20:58.598: %SSH-5-ENABLED: SSH 1.99 has been enabled
R-HQ(config-line)#
R-HQ#
%SYS-5-CONFIG_I: Configured from console by console
```

Figure 36

```
R-HQ#show running-config | section vty
line vty 0 4
R-HQ#
R-HQ#
R-HQ#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
R-HQ(config)#line vty 0 4
R-HQ(config-line)#login authentication NB-AAA
R-HQ(config-line)#transport input ssh
R-HQ(config-line)#exit
R-HQ(config)#end
R-HQ#
%SYS-5-CONFIG_I: Configured from console by console
write memory
Building configuration...
[OK]
```

Figure 37

```
R-HQ#show running-config | section vty
line vty 0 4
 login authentication NB-AAA
 transport input ssh
```

Figure 38

✓ Verifying AAA via SSH from PC0

```
C:\>ping 192.168.20.10

Pinging 192.168.20.10 with 32 bytes of data:

Reply from 192.168.20.10: bytes=32 time=27ms TTL=126
Reply from 192.168.20.10: bytes=32 time=27ms TTL=126
Reply from 192.168.20.10: bytes=32 time=16ms TTL=126
Reply from 192.168.20.10: bytes=32 time=28ms TTL=126

Ping statistics for 192.168.20.10:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 16ms, Maximum = 28ms, Average = 24ms
```

Figure 39

```
C:\>
C:\>ssh -l netadmin 192.168.10.1
Invalid Command.

C:\>ssh -l netadmin 192.168.10.1

Password:
% Login invalid


Password:

Password:
R-HQ>
```

Figure 40

```
C:\>ssh -l netadmin 192.168.10.1

Password:
R-HQ>
```

Figure 41

VPN Configuration (Free-Choice Config)

- Router0

```
Router(config)#hostname R-HQ
R-HQ(config)#interface gigabitEthernet 0/0
R-HQ(config-if)#ip address 192.168.10.1 255.255.255.0
R-HQ(config-if)#no shutdown

R-HQ(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to up
exit
R-HQ(config)#interface gigabitEthernet 0/1
R-HQ(config-if)#ip address 203.0.113.1 255.255.255.252
R-HQ(config-if)#no shutdown

R-HQ(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/1, changed state to up
exit
R-HQ(config)#ip route 192.168.20.0 255.255.255.0 203.0.113.2
R-HQ(config)#username netadmin privilege 15 secret Cisco123!
R-HQ(config)#aaa new-model
R-HQ(config)#aaa authentication login NB-AAA local
R-HQ(config)#ip domain-name northbridge.local
R-HQ(config)#crypto key generate rsa
The name for the keys will be: R-HQ.northbridge.local
Choose the size of the key modulus in the range of 360 to 4096 for your
  General Purpose Keys. Choosing a key modulus greater than 512 may take
  a few minutes.

How many bits in the modulus [512]: 1024
% Generating 1024 bit RSA keys, keys will be non-exportable...[OK]

R-HQ(config)#line vty 0 4
*Mar 1 0:6:4.470: %SSH-5-ENABLED: SSH 1.99 has been enabled
R-HQ(config-line)#login authentication NB-AAA
R-HQ(config-line)#transport input ssh
R-HQ(config-line)#exit
```

Figure 42

```
R-HQ(config-line)#exit
R-HQ(config)#
R-HQ(config)#access-list 100 permit ip 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255
```

Figure 43

```
R-HQ(config-isakmp)#hash ?
  md5  Message Digest 5
  sha  Secure Hash Standard
R-HQ(config-isakmp)#hash sha
R-HQ(config-isakmp)#authentication pre-share
R-HQ(config-isakmp)#group 14
                      ^
% Invalid input detected at '^' marker.

R-HQ(config-isakmp)#group ?
  1  Diffie-Hellman group 1
  2  Diffie-Hellman group 2
  5  Diffie-Hellman group 5
R-HQ(config-isakmp)#
R-HQ(config-isakmp)#group 5
```

Figure 44

```
R-HQ(config-isakmp)#authentication pre-share
R-HQ(config-isakmp)#exit
R-HQ(config)#crypto isakmp key NorthbridgeKey123 address 203.0.113.2
R-HQ(config)#crypto ipsec transform-set NB-SET esp-aes 256 ?
  esp-md5-hmac  ESP transform using HMAC-MD5 auth
  esp-sha-hmac  ESP transform using HMAC-SHA auth
  <cr>
R-HQ(config)#crypto ipsec transform-set NB-SET esp-aes 256 esp-sha-hmac
R-HQ(config)#crypto map NB-MAP 10 ipsec-isakmp
% NOTE: This new crypto map will remain disabled until a peer
        and a valid access list have been configured.
R-HQ(config-crypto-map)#set peer 203.0.113.2
R-HQ(config-crypto-map)#set transform-set NB-SET
R-HQ(config-crypto-map)#match address 100
R-HQ(config-crypto-map)#exit
R-HQ(config)#interface gigabitEthernet 0/1
R-HQ(config-if)#crypto map NB-MAP
*Jan  3 07:16:26.785: %CRYPTO-6-ISAKMP_ON_OFF: ISAKMP is ON
R-HQ(config-if)#exit
R-HQ(config)#end
R-HQ#
%SYS-5-CONFIG_I: Configured from console by console
write memory
Building configuration...
[OK]
R-HQ#
```

Figure 45

- Router1

```
Router>enable
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#hostname R-Branch
R-Branch(config)#interface gigabitEthernet 0/0
R-Branch(config-if)#ip address 192.168.20.1 255.255.255.0
R-Branch(config-if)#no shutdown

R-Branch(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0, changed state to up
exit
R-Branch(config)#interface gigabitEthernet 0/1
R-Branch(config-if)#ip address 203.0.113.2 255.255.255.252
R-Branch(config-if)#no shutdown

R-Branch(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/1, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to up
exit
```

Figure 46

```
R-Branch(config)#interface gigabitEthernet 0/1
R-Branch(config-if)#ip address 203.0.113.2 255.255.255.252
R-Branch(config-if)#no shutdown

R-Branch(config-if)#
%LINK-5-CHANGED: Interface GigabitEthernet0/1, changed state to up

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/1, changed state to up
exit
R-Branch(config)#ip route 192.168.10.0 255.255.255.0 203.0.113.1
R-Branch(config)#access-list 100 permit ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
R-Branch(config)#crypto isakmp policy 10
R-Branch(config-isakmp)#encryption aes 256
R-Branch(config-isakmp)#hash sha
R-Branch(config-isakmp)#authentication pre-share
R-Branch(config-isakmp)#group 5
R-Branch(config-isakmp)#exit
R-Branch(config)#crypto isakmp key NorthbridgeKey123 address 203.0.113.1
R-Branch(config)#crypto ipsec transform-set NB-SET esp-aes 256 esp-sha-hmac
R-Branch(config)#crypto map NB-MAP 10 ipsec-isakmp
% NOTE: This new crypto map will remain disabled until a peer
        and a valid access list have been configured.
R-Branch(config-crypto-map)#set peer 203.0.113.1
R-Branch(config-crypto-map)#set transform-set NB-SET
R-Branch(config-crypto-map)#match address 100
R-Branch(config-crypto-map)#exit
R-Branch(config)#interface gigabitEthernet 0/1
R-Branch(config-if)#crypto map NB-MAP
*Jan  3 07:16:26.785: %CRYPTO-6-ISAKMP_ON_OFF: ISAKMP is ON
R-Branch(config-if)#exit
R-Branch(config)#end
R-Branch#
%SYS-5-CONFIG_I: Configured from console by console
write memory
Building configuration...
[OK]
R-Branch#
```

Figure 47

✓ Triggering and Verifying the VPN Tunnel

- R-HQ Router

```
R-HQ#show crypto isakmp sa
IPv4 Crypto ISAKMP SA
dst             src             state          conn-id slot status
203.0.113.2     203.0.113.1     QM_IDLE           1092    0 ACTIVE


IPv6 Crypto ISAKMP SA
```

Figure 48

```
R-HQ#show crypto ipsec sa

interface: GigabitEthernet0/1
    Crypto map tag: NB-MAP, local addr 203.0.113.1

   protected vrf: (none)
   local  ident (addr/mask/prot/port): (192.168.10.0/255.255.255.0/0/0)
   remote  ident (addr/mask/prot/port): (192.168.20.0/255.255.255.0/0/0)
   current_peer 203.0.113.2 port 500
    PERMIT, flags={origin_is_acl,}
   #pkts encaps: 4, #pkts encrypt: 4, #pkts digest: 0
   #pkts decaps: 4, #pkts decrypt: 4, #pkts verify: 0
   #pkts compressed: 0, #pkts decompressed: 0
   #pkts not compressed: 0, #pkts compr. failed: 0
   #pkts not decompressed: 0, #pkts decompress failed: 0
   #send errors 1, #recv errors 0

     local crypto endpt.: 203.0.113.1, remote crypto endpt.:203.0.113.2
     path mtu 1500, ip mtu 1500, ip mtu idb GigabitEthernet0/1
     current outbound spi: 0x685481E2(1750368738)

     inbound esp sas:
      spi: 0x1FC95685(533288581)
 --More--
```

Figure 49

```
R-HQ#ping 192.168.10.10

Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 192.168.10.10, timeout is 2 seconds:
.!!!!
Success rate is 80 percent (4/5), round-trip min/avg/max = 5/10/21 ms
```

Figure 50

- R-Branch Router

```
R-Branch>ping 192.168.20.10

Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 192.168.20.10, timeout is 2 seconds:
.!!!!
Success rate is 80 percent (4/5), round-trip min/avg/max = 5/13/21 ms

R-Branch>ping 192.168.10.10

Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 192.168.10.10, timeout is 2 seconds:
!!!!!
Success rate is 100 percent (5/5), round-trip min/avg/max = 13/16/17 ms
```

Figure 51

Palugaswewa K.I.K.I.B - Plan linked Configuration - VLAN Segmentation

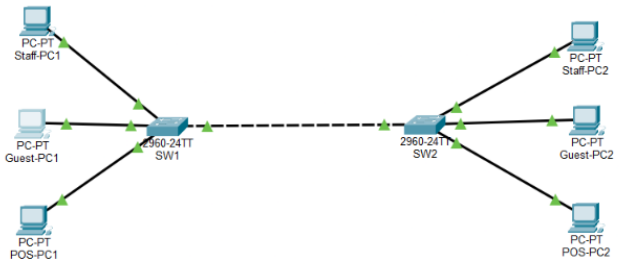


Figure 52. Starting topology

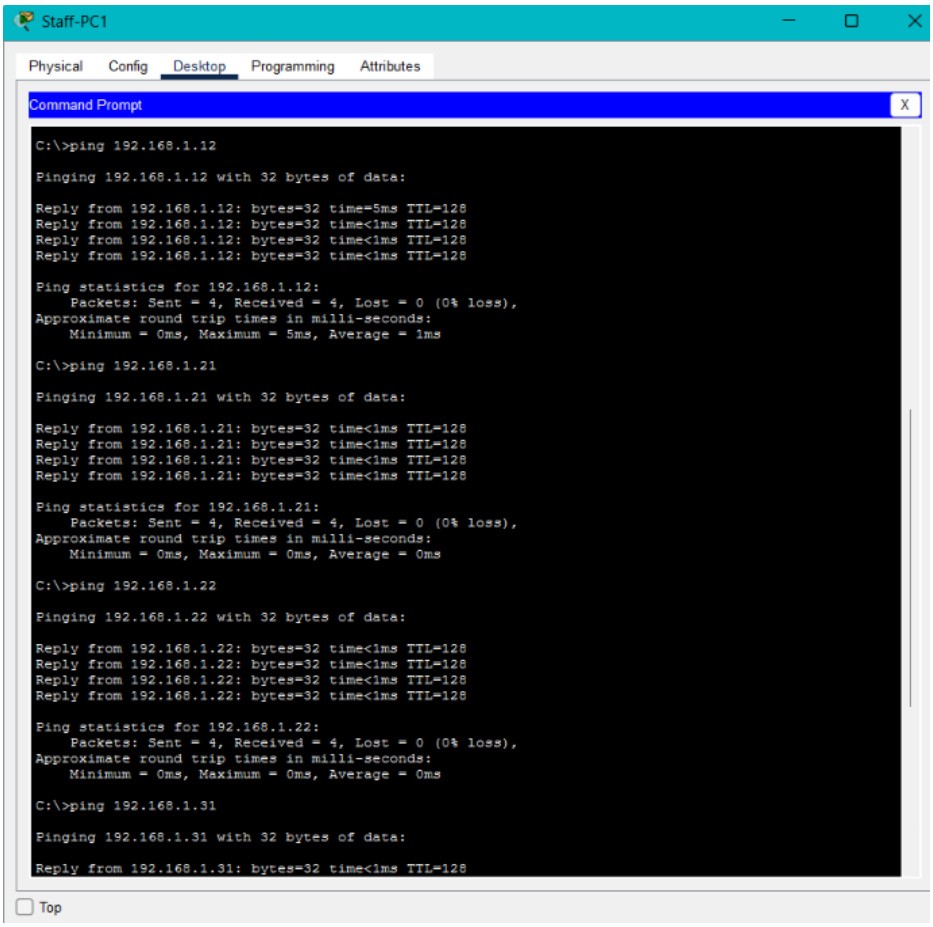


Figure 53. That's the flat network problem. A staff PC can reach guest, and POS device directly

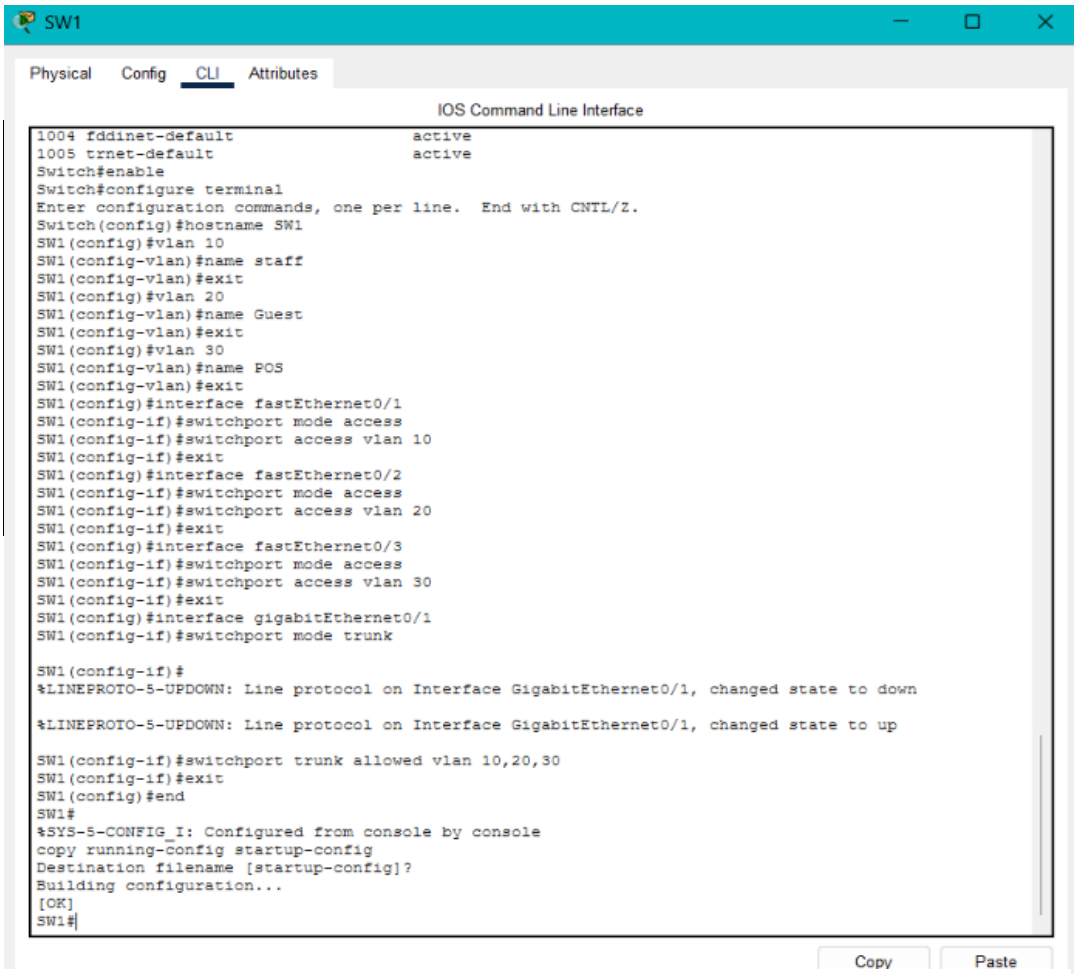


Figure 55. Configure SW1

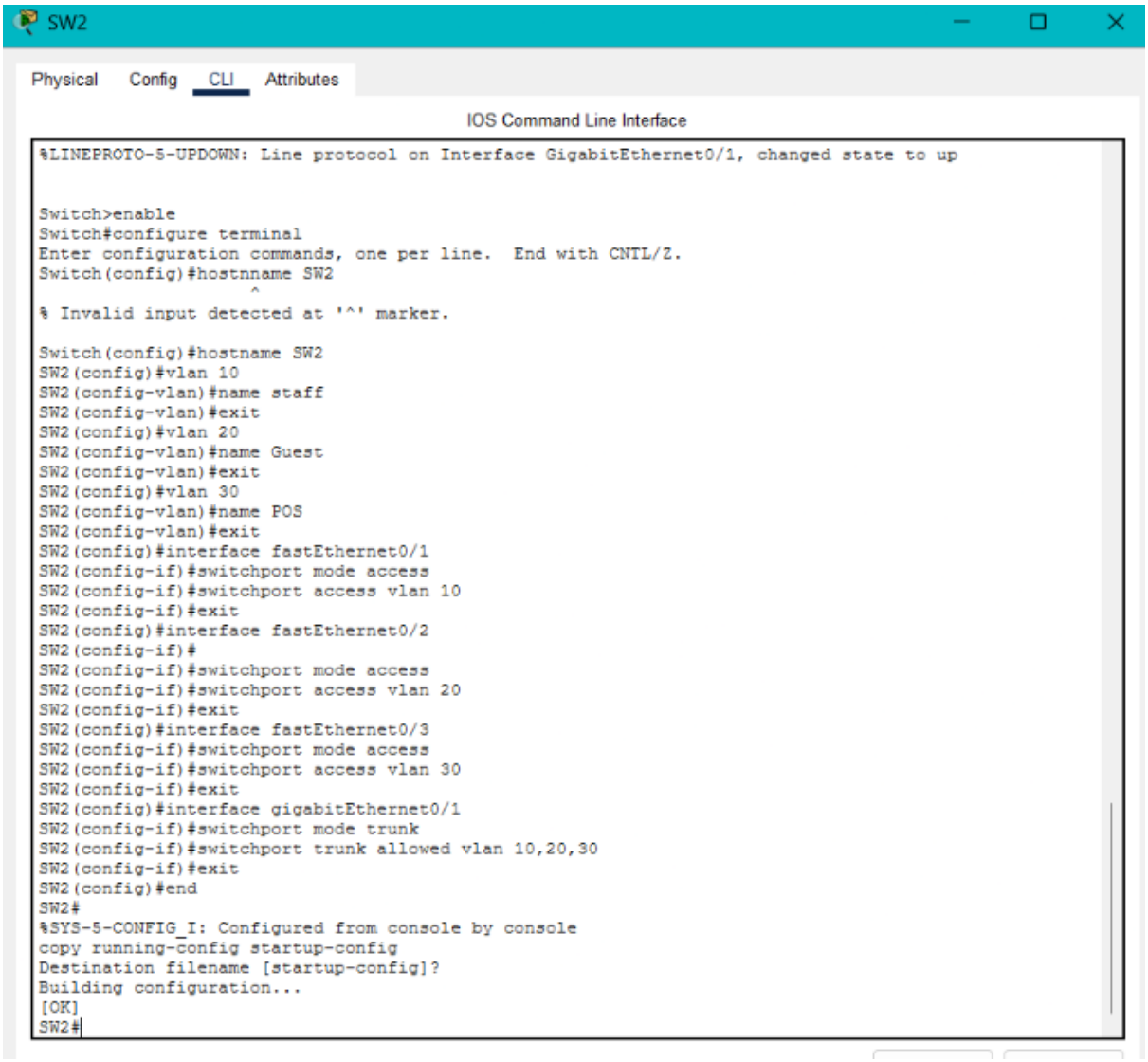


Figure 56. Configure SW2

```
SW1#show vlan brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa0/4, Fa0/5, Fa0/6, Fa0/7
                                                Fa0/8, Fa0/9, Fa0/10, Fa0/11
                                                Fa0/12, Fa0/13, Fa0/14, Fa0/15
                                                Fa0/16, Fa0/17, Fa0/18, Fa0/19
                                                Fa0/20, Fa0/21, Fa0/22, Fa0/23
                                                Fa0/24, Gig0/2
10   staff                            active    Fa0/1
20   Guest                            active    Fa0/2
30   POS                              active    Fa0/3
1002 fddi-default                     active
1003 token-ring-default               active
1004 fddinet-default                  active
1005 trnet-default                    active
```

Figure 57. VLAN 10 Staff with Fa0/1, VLAN 20 Guest with Fa0/2, VLAN 30 POS with Fa0/3. Everything else stays is VLAN 1 (Switch1)

```
SW1#show interfaces trunk
Port        Mode         Encapsulation  Status        Native vlan
Gig0/1      on           802.1q         trunking      1

Port        Vlans allowed on trunk
Gig0/1      10,20,30

Port        Vlans allowed and active in management domain
Gig0/1      10,20,30

Port        Vlans in spanning tree forwarding state and not pruned
Gig0/1      10,20,30
```

Figure 58. Gi0//1 listed with mode on, encapsulation 802.1q, status trunking and VLANs 10, 20, 30 allowed (Switch 1)

```
SW1#show interfaces fastEthernet0/1 switchport
Name: Fa0/1
Switchport: Enabled
Administrative Mode: static access
Operational Mode: static access
Administrative Trunking Encapsulation: dot1q
Operational Trunking Encapsulation: native
Negotiation of Trunking: Off
Access Mode VLAN: 10 (staff)
Trunking Native Mode VLAN: 1 (default)
Voice VLAN: none
Administrative private-vlan host-association: none
Administrative private-vlan mapping: none
Administrative private-vlan trunk native VLAN: none
Administrative private-vlan trunk encapsulation: dot1q
Administrative private-vlan trunk normal VLANs: none
Administrative private-vlan trunk private VLANs: none
Operational private-vlan: none
Trunking VLANs Enabled: All
Pruning VLANs Enabled: 2-1001
Capture Mode Disabled
Capture VLANs Allowed: ALL
Protected: false
Unknown unicast blocked: disabled
Unknown multicast blocked: disabled
Appliance trust: none
```

Figure 59. Access mode VLAN: 10 (Staff) (Switch1)

```
SW2#show vlan brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa0/4, Fa0/5, Fa0/6, Fa0/7
                                                Fa0/8, Fa0/9, Fa0/10, Fa0/11
                                                Fa0/12, Fa0/13, Fa0/14, Fa0/15
                                                Fa0/16, Fa0/17, Fa0/18, Fa0/19
                                                Fa0/20, Fa0/21, Fa0/22, Fa0/23
                                                Fa0/24, Gig0/2
10   staff                            active    Fa0/1
20   Guest                            active    Fa0/2
30   POS                              active    Fa0/3
1002 fddi-default                     active
1003 token-ring-default               active
1004 fddinet-default                  active
1005 trnet-default                    active
```

Figure 60. VLAN 10 Staff with Fa0/1, VLAN 20 Guest with Fa0/2, VLAN 30 POS with Fa0/3. Everything else stays in VLAN 1. [Switch 2]

Figure 61

```
SW2#show interfaces trunk
Port        Mode         Encapsulation  Status        Native vlan
Gig0/1      on           802.1q         trunking      1

Port        Vlans allowed on trunk
Gig0/1      10,20,30

Port        Vlans allowed and active in management domain
Gig0/1      10,20,30

Port        Vlans in spanning tree forwarding state and not pruned
Gig0/1      10,20,30
```

Figure 61. Gi0/1 listed with mode on, encapsulation 802.1q, status trunking, and VLANs 10, 20, 30 allowed. [Switch 2]

```
SW2#show interfaces fastEthernet0/1 switchport
Name: Fa0/1
Switchport: Enabled
Administrative Mode: static access
Operational Mode: static access
Administrative Trunking Encapsulation: dot1q
Operational Trunking Encapsulation: native
Negotiation of Trunking: Off
Access Mode VLAN: 10 (staff)
Trunking Native Mode VLAN: 1 (default)
Voice VLAN: none
Administrative private-vlan host-association: none
Administrative private-vlan mapping: none
Administrative private-vlan trunk native VLAN: none
Administrative private-vlan trunk encapsulation: dot1q
Administrative private-vlan trunk normal VLANs: none
Administrative private-vlan trunk private VLANs: none
Operational private-vlan: none
Trunking VLANs Enabled: All
Pruning VLANs Enabled: 2-1001
Capture Mode Disabled
Capture VLANs Allowed: ALL
Protected: false
Unknown unicast blocked: disabled
Unknown multicast blocked: disabled
Appliance trust: none
```

Figure 62. Access Mode VLAN: 10 (Staff) (Switch 2)

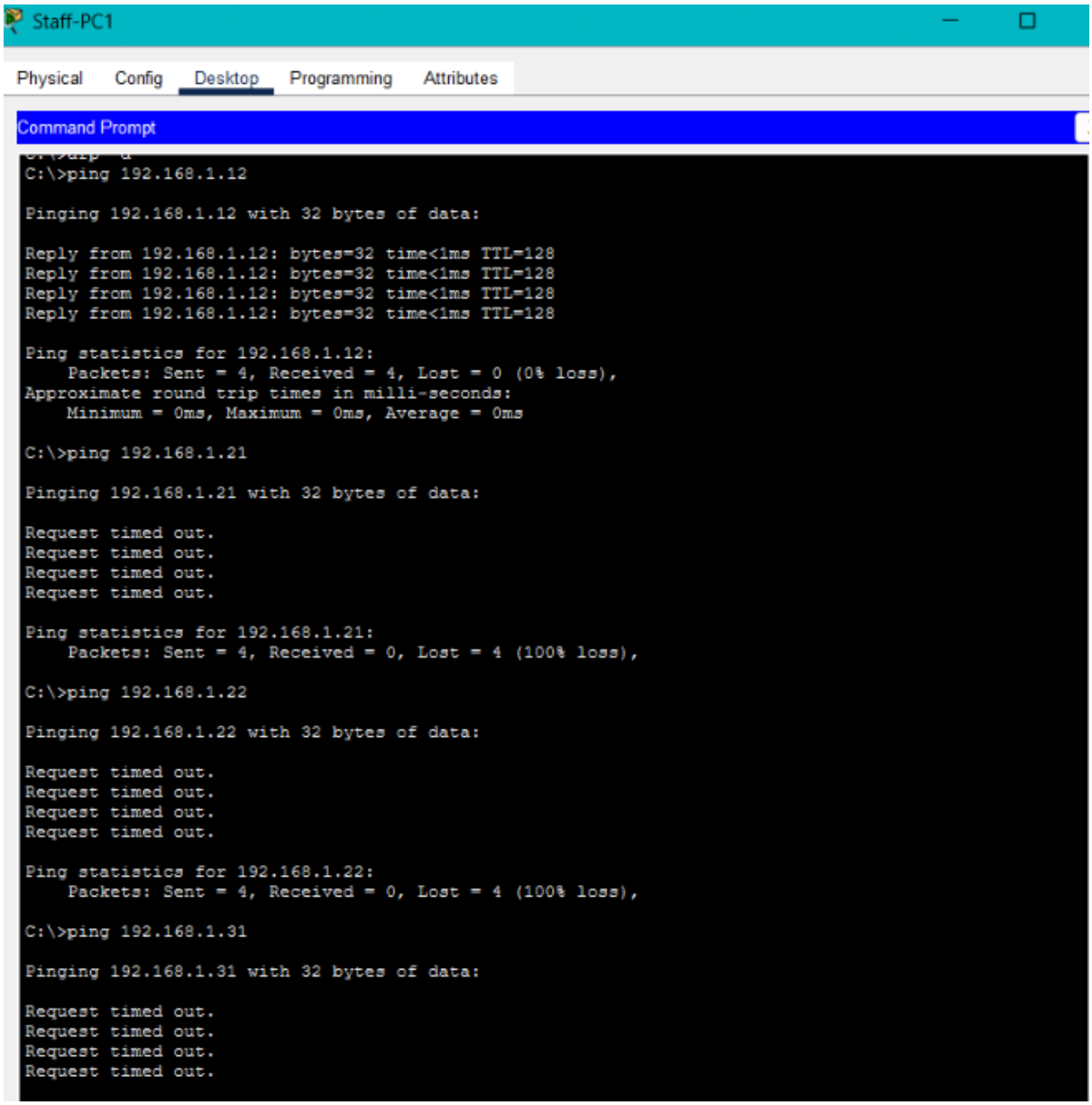


Figure 63.

Staff-PC1 connectivity test after VLAN segmentation. Staff-PC1 (192.168.1.11, VLAN 10) successfully pings Staff-PC2 (192.168.1.12), which is in the same VLAN on the other switch, confirming VLAN 10 traffic crosses the SW1-SW2 trunk. Pings to Guest-PC1 (.21), Guest-PC2 (.22), POS-PC1 (.31) and POS-PC2 (.32) fail, showing that devices in the Guest (VLAN 20) and POS (VLAN 30) segments are no longer reachable from the Staff segment. This contrasts with the pre-segmentation test (Figure Y), where all five destinations replied.

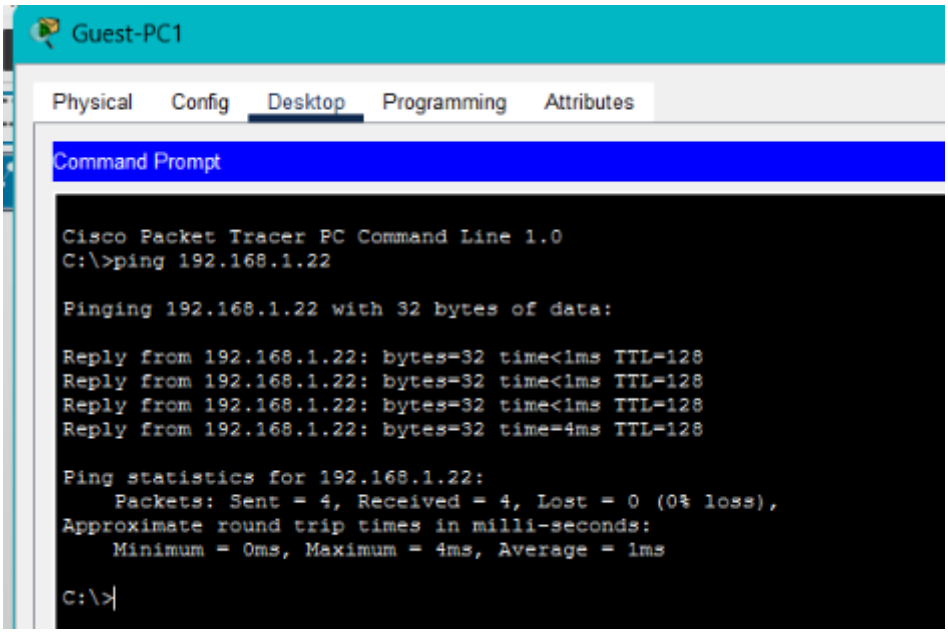


Figure 64.

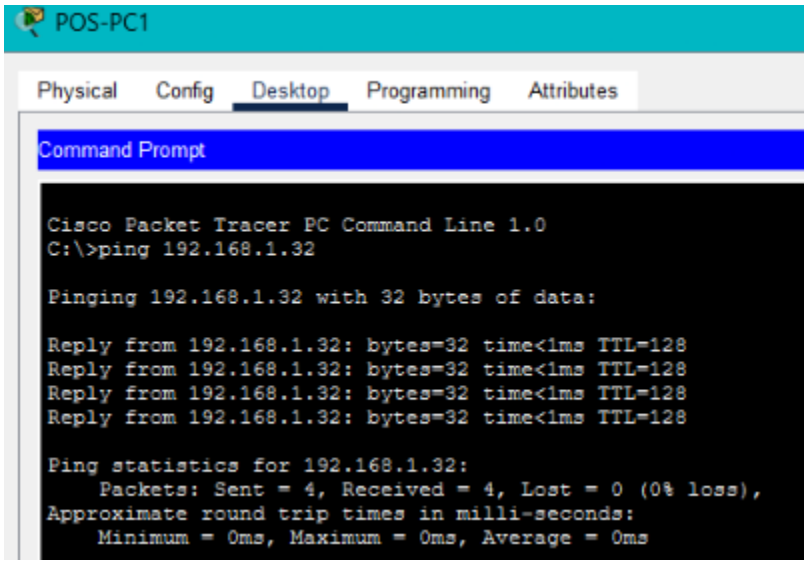


Figure 65

Figures 64, 65**:** Same-VLAN connectivity on the Guest and POS segments. Guest-PC1 (192.168.1.21) successfully pings Guest-PC2 (192.168.1.22), and POS-PC1 (192.168.1.31) successfully pings POS-PC2 (192.168.1.32). Each pair is connected to different switches, so these replies confirm that VLAN 20 and VLAN 30 traffic is carried across the 802.1Q trunk. Together with Figure Z, this shows that segmentation isolates the VLANs from each other without breaking communication within each VLAN.

Palugaswewa K.I.K.I.B - SSH Configuration for Secure Device Management - Free choice configuration

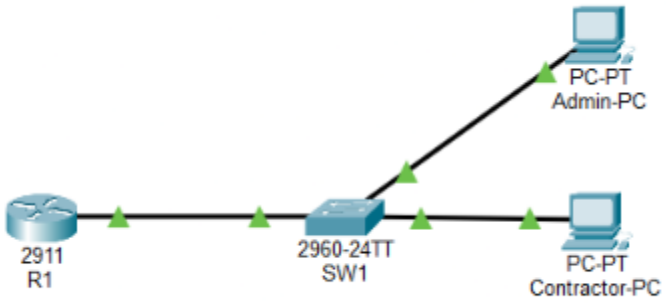


Figure 66. Network topology: Admin PC and contractor PC connect though SW1 to router R1

```
R1#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
R1(config)#line vty 0 4
R1(config-line)#password telnetpass
R1(config-line)#login
R1(config-line)#transport input telnet
R1(config-line)#end
R1#
%SYS-5-CONFIG_I: Configured from console by console
```

Figure 67.Before hardening: R1 configured with Telnet – only VTY access and a shared password

```
C:\>telnet 192.168.1.1
Trying 192.168.1.1 ...Open


User Access Verification

Password:
R1>enable
Password:
R1#
```

Figure 68. Before hardening: a successful Telnet login from Admin - PC using the shared password

Telnet has no encryption, and everyone shares one password with no individual accountability, so there's no record of who logged in. This matches Northbridge's shared-account problem.

```
R1#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
R1(config)#ip domain-name northbridge.local
R1(config)#username admin1 privilege 15 secret Admin1@Pass
R1(config)#username contractor1 privilege 1 secret Contr1@Pass
R1(config)#crypto key generate rsa general-key modulus 2048
The name for the keys will be: R1.northbridge.local

% The key modulus size is 2048 bits
% Generating 2048 bit RSA keys, keys will be non-exportable...[OK]
*Mar 1 0:24:29.867: %SSH-5-ENABLED: SSH 1.99 has been enabled
R1(config)#ip ssh version 2
R1(config)#ip ssh time-out 60
R1(config)#ip ssh authentication-retries 3
R1(config)#line vty 0 4
R1(config-line)#no password
R1(config-line)#login local
R1(config-line)#transport
% Incomplete command.
R1(config-line)#transport input ssh
R1(config-line)#exec-timeout 5 0
R1(config-line)#end
R1#
%SYS-5-CONFIG_I: Configured from console by console
copy running-config startup-config
Destination filename [startup-config]?
Building configuration...
[OK]
R1#
```

Figure 69.SSH configuration: domain name, individual user accounts, RSA keys, SSH version 2 and SSH – only VTY lines

```
R1#
R1#show ip ssh
SSH Enabled - version 2.0
Authentication timeout: 60 secs; Authentication retries: 3
R1#show running-config | section line vty
line vty 0 4
 exec-timeout 5 0
 login local
 transport input ssh
R1#show crypto key mypubkey rsa
% Key pair was generated at: 0:24:29 UTC March 1 1993
Key name: R1.northbridge.local
 Storage Device: not specified
 Usage: General Purpose Key
 Key is not exportable.
 Key Data:
 000010c8  0000271b  00002e21  00006240  000034c2  0000514b  00005d73  000079df
 00006f5e  0000464a  0000143c  0000077b  000056ee  00006bb4  000067f2  000037bb
 00005e49  00003e92  000020ce  00003404  00004312  00001889  00003a30  314a
% Key pair was generated at: 0:24:29 UTC March 1 1993
Key name: R1.northbridge.local.server
Temporary key
 Usage: Encryption Key
 Key is not exportable.
 Key Data:
 0000313d  00005551  0000423f  00006126  00003fce  00006c69  00005ccf  00007929
 00002ae4  00005309  00006d89  00004471  00006ef7  00003a59  00002d45  00007379
 0000295e  00007de0  00002ebb  00001e35  00006214  0000563f  0000165b  2c5f
```

Figure 70. SSH verification: show IP ssh confirms SSH is enabled and running version 2.0. The VTY lines show login local and transport input SSH, and the RSA key pair exists.

```
[Connection to 192.168.1.1 closed by foreign host]
C:\>ssh -l admin1 192.168.1.1

Password:


R1#
```

Figure 71. SSH access: Admin – PC logs into R1 over SSH as admin 1

```
C:\>telnet 192.168.1.1
Trying 192.168.1.1 ...Open

[Connection to 192.168.1.1 closed by foreign host]
C:\>
```

Figure 72. Telnet blocked: The Telnet attempt to R1 is refused after hardening

```
C:\>ssh -l contractor1 192.168.1.1

Password:
% Login invalid


Password:



R1>show users
    Line       User       Host(s)              Idle       Location
   0 con 0                 idle                 00:00:00
*390 vty 0     contractor1idle                 00:00:00

  Interface    User               Mode         Idle     Peer Address
R1>show ssh
Connection      Version Mode Encryption           Hmac      State             Username
0               1.99    IN   aes128-cbc       hmac-sha1     Session Started         contractor1
0               1.99    OUT  aes128-cbc       hmac-sha1     Session Started         contractor1
%No SSHv1 server connections running.
R1>
```

Figure 73. Failed login: SSH with a wrong password is rejected. Show users and show SSH list admin1 and contractor as separate sessions

7. Conclusion

This report provides a security evaluation and enhancement plan for Northbridge Savings & Finance, which was requested after the discovery of the vulnerabilities presented in the scenario and two issues that arose to the board's attention. While working individually, each of the four group members developed eight possible threats using the asset to risk method, which was based on the company's technical, administrative, and infrastructural weaknesses. The four group members narrowed down the list of threats to eight controls, which would address the issues found with network segmentation, centralized authentication, and port-level device restriction as the primary and patch management, vendor assessment, and data/BYOD policy controls as the secondary, as there were no other comprehensive coverage options. The group's Control Minimization justification explained why exactly the eight controls were chosen, which alternatives were available and discarded, and acknowledged the overlap that was allowed and would need to be addressed.

Aside from the eight controls, each group member developed solutions for the four technology areas – VPN, AAA, secure network design, and IDS/IPS – and presented their individual reasoning. After comparing the sixteen options, the group chose Cisco AnyConnect, Cisco ISE, the hub-spoke network architecture with the firewall at the branch level, and Cisco Secure IPS as the four technologies that would be recommended to the company. The four technologies were chosen for being able to create a singular Cisco-based ecosystem that would address the issues presented in the scenario more directly rather than using an alternative approach. Finally, to prove that the two technologies would have been viable solutions for the company, each group member configured two network hardening measures in Cisco Packet Tracer and demonstrated their working knowledge in screenshots.

Overall, the plan will directly address the two issues that required the CTO's immediate attention by eliminating the threat that almost compromised the company using vishing by implementing centralized authentication with multifactor authorization instead of relying on shared credentials. It will also resolve the issue of the ransomware propagating through the network by designing a structure that will segment the network at the branch level and utilize an inline intrusion prevention design. As the third-party payment system is expected to be integrated within the next two quarters, the eight controls and four recommended technologies are considered the baseline that Northbridge should reach before said integration is performed. The five threats and controls that were not prioritized by the group, namely, security awareness training, physical access controls, centralized logging, and backup and recovery procedures, will be addressed in the following stages of the security program.

8. Appendices

Appendix A: Kosgollage S R - IT24102747

VPN proposal

Recommended Solution: Cisco AnyConnect Secure Mobility Client (SSL VPN)

- I suggest considering utilizing Cisco AnyConnect Secure Mobility Client, an SSL based VPN solution implemented on Cisco ASA/FTD, to grant secure remote access to the company's internal systems for the remote and traveling employees, as well as the two external IT support contractors, which require individual authentication and centralized remote access management.

Alternative Considered: Site-to-Site IPsec VPN

- I decided to go with a Site-to-Site IPsec VPN as my only option for remote access, since that's already a given for Northbridge's connections between their offices and the head office. The technology would be deployed regardless in that scenario, so adopting the same site-to-site model for covering the needs of remote and travelling staff members was simply a logical expansion of what was already in place.

Why Site-to-Site IPsec VPN Was Rejected for This Purpose

- Site-to-Site IPsec VPN is a technology which establishes permanent, trusted tunnels between 2 fixed network endpoints. Usually, 2 routers or firewalls at known, static locations (branch office and head office for example). It is not suitable for a remote access population as individuals, remote and travelling staff, would be connecting from variable, unknown locations (home, hotel, client sites) and the two external IT support contractors aren't actually on Northbridge's network in the first place. Site-to-Site VPNs have no concept of an individual user identity. They authenticate the site (not the person using that site). This is the same design oversight which caused Northbridge's current issue; a single shared VPN account in common use between all remote staff and both contractors, despite the scenario explicitly stating there is "no individual accountability and no multi-factor authentication". Deploying the technology as Northbridge would not resolve that design flaw, only replicate the same problem in a different form as every remote user or contractor would be authenticating via the same tunnel/credential as opposed to being individual, auditable identities.

Why AnyConnect Is the Better Fit for Northbridge Specifically

- AnyConnect is a client-based, per-user remote-access VPN; this means that every user (traveling employees or any of the two external contractors) authenticate with their credentials before a tunnel is established. Furthermore, AnyConnect can make use of the existing central AAA backend (RADIUS/TACACS+) which can participate in the centralized AAA control envisioned by Northbridge (see Control C2 in the group's Layered Security Plan). As a result, it would address both issues raised by the scenario: the absence of individual accountability and the lack of multifactor authentication options. It would also give Northbridge the ability to terminate the access of one of the contractors immediately if needed without impacting the AAA solution for the other users, which is not the case with the current setup.
- As Northbridge's core remote-access problem is fundamentally an identity and accountability problem, AnyConnect is the more directly responsive solution. Site-to-Site IPsec VPN remains the correct technology for permanent branch-to-head-office links, but it is not proposed here as the solution to individual remote/contractor access.

AAA solution proposal

For the centralized authentication requirement established by Northbridge, I suggest Cisco Identity Services Engine (ISE), an enterprise-level AAA and network access control platform that can replace the current home-grown solution where each application and device has its own set of users and credentials.

Alternative Considered: FreeRADIUS

- One of the alternatives I considered was FreeRADIUS, which is an open-source RADIUS server. It is a well-established AAA solution that can provide centralized authentication for network devices, VPN access, and Wi-Fi. This no-licensing fee solution appealed to me, given that Northbridge has invested almost nothing in IT infrastructure and would have to design its AAA infrastructure from scratch.

Why FreeRADIUS Was Rejected for This Purpose

- FreeRADIUS was rejected for three reasons that specifically applied to the situation of Northbridge. First, FreeRADIUS does not support multifactor authentication natively – and adding that capability would require either new plugins or changes to its core code that an unprepared organization with no security awareness training program and limited IT security maturity would be unlikely to implement correctly without assistance, which was unavailable per the scenario description. This consideration is particularly relevant given the explicitly mentioned lack of MFA as one of the security weaknesses the board wanted to address. A product featuring it as a native feature would involve considerably lower risks of implementation error on the part of the client. Second, FreeRADIUS does

not natively support network access control – while it can authenticate users, it cannot assign them specific network segments without additional configuration. Given that the group's Layered Security Plan explicitly relied on network segmentation (Control C1) as its primary security discipline and containment design philosophy, one can reasonably assume that a product with deeper NAC integration would be more desirable to the client than one that only performs authentication. Third, FreeRADIUS is an unsupported open source project – there is no commercial entity behind its development, and unlike paid enterprise solutions, it cannot be officially maintained or troubleshot by a customer support team. Given that Northbridge was a financial institution that engaged in the high-profile and highly regulated activity of payment processing, having a AAA server that could not be directly supported by an authorized service provider was unacceptable.

Why Cisco ISE Is the Better Fit for Northbridge Specifically

- Cisco ISE directly addresses Northbridge's stated problem: it unifies per-device, per-application local account sprawl into a single centralized identity source with support for both RADIUS and TACACS+ protocols, which allows it to handle network device administration, Wi-Fi authentication, and be integrated directly with the Cisco AnyConnect VPN solution they have already proposed to the scenario for both remote and contractor access. This means the same identity used by a branch employee to authenticate into a network switch can be used to govern that employee's VPN session, thereby patching the "every device and application maintains its own local set of user accounts" gap the scenario describes in the same system instead of across a plurality of them. ISE also natively supports MFA integration (including with Cisco Duo) to directly address the scenario's explicit call-out that "there is no multi-factor authentication anywhere in the organization." Finally, ISE's network access control capability allows Northbridge to dynamically assign users and devices to the correct network segment at the point of authentication, which directly reinforces and operationalizes the group's segmentation control (C1) rather than functioning as a standalone authentication system disconnected from the rest of the security plan.
- As, Northbridge's authentication problem is compounded by an equally urgent segmentation and MFA problem, and the fact that the organization is preparing for a formal third-party payment integration that will invite regulatory scrutiny, Cisco ISE's tighter integration with the rest of the proposed security architecture and its vendor-backed reliability make it the stronger recommendation than the more cost-effective FreeRADIUS despite the licensing cost.

Network Architecture.

Recommended solution: Hub-and-Spoke model with a firewall deployed at each branch office (spoke) in addition to the head office (hub)

Alternative Considered: Three-Tier Zone Architecture (Perimeter + Internal + DMZ)

- I considered a **Three-Tier Zone Architecture**, centralizing firewall enforcement at head office through a perimeter firewall (internet-facing), an internal firewall protecting the core banking zone, and a DMZ hosting the online banking portal and mobile app. This is a well-established enterprise pattern and would clearly satisfy the "multiple firewalls and defined zones" requirement, with all critical enforcement concentrated where the core banking database and customer-facing services reside.

Why the Three-Tier Zone Architecture Was Rejected as the Primary Model

- While centralizing enforcement at head office would protect the core banking database effectively, it doesn't take into account the reported attack pattern which is currently a live risk to Northbridge: the regional industry association's finding that 'ransomware incidents at similar mid-sized financial firms began with a single compromised branch workstation and spread rapidly across an unsegmented network.' A three-tier model with firewalls only at head office doesn't guard against a compromise at the point it takes place -- a branch workstation infected with ransomware would still be sitting on a flat, unfiltered branch network with the rest of that branch's systems and POS equipment before ever reaching a head-office firewall, meaning that the malware would have already had lateral distribution within that branch before any enforcement point would have encountered the traffic. Given that Northbridge has six branch offices, and the scenario's own cited threat pattern begins at the branch level, a purely HQ-centric firewall model would leave the actual site of initial compromise without any protection.

Why Hub-and-Spoke with Branch Firewalls Is the Better Fit for Northbridge Specifically

- A Hub-and-Spoke architecture would involve deploying a firewall with zones at each of the six branch offices, not just the head office, thereby providing segmentation at the local level for each branch’s guest wireless, POS systems, and staff workstations; in the event of an attack on one branch’s staff workstations, which seems to be the scenario the industry association has in mind, the breach would be limited to that branch rather than propagating through the dedicated links to other branches and the head office. The head office would still have its own firewall(s) as the hub, which would protect the core banking database, the DMZ-hosted online banking portal and mobile banking application, and the perimeter around the future third-party payment processor connection, directly addressing the concern about the potential blast radius of a breach, which is Northbridge’s primary risk scenario as described.

- This architecture would also remain fully compatible with the centralized services already proposed: while enforcement is distributed to each branch, policy is not — Cisco ISE (the proposed AAA solution) can centrally push authentication and segmentation policy to branch firewalls, ensuring that while each branch enforces its own zone boundaries locally, access rules and VLAN assignments are centrally defined and consistent across the six sites rather than independently configured. Likewise, remote and travelling staff connecting via Cisco AnyConnect continue to authenticate centrally and are placed into the appropriate zone at whichever site (branch or HQ) their access policy dictates. In this way, the architecture is both decentralized in enforcement but centrally governed in policy — giving Northbridge both the containment benefit the scenario specifically calls for and the operational consistency of centrally administered security posture.

IDS/IPS solution

Recommended Solution: Cisco Secure IPS (Next-Generation Intrusion Prevention System)

- For Northbridge's intrusion detection and prevention requirement, I would recommend using Cisco Secure IPS for deploying an inline network intrusion prevention that has been integrated into Cisco's firewall/router infrastructure that will close the gap that the scenario specifically identifies; Northbridge has "no intrusion detection or prevention capability anywhere on the network, leaving the bank blind to reconnaissance or active compromise until damage is already visible."

Alternative Considered: Snort

- I was considering a popular open-sourced network intrusion detection and prevention software called Snort as a cost-effective IDS/IPS solution. The open-sourced firewall is widely adopted and has well-maintained rule sets. Moreover, the Snort IPS (intrusion prevention system) can be directly deployed on the Cisco IOS router, which means that it can be technically feasible to use it on Northbridge's existing Cisco hardware.

Why Snort Was Rejected for This Purpose

- I would argue that the Snort system was ultimately rejected due to factors specific to the current maturity state of Northbridge's organizational IT security practices. First, Snort requires ongoing manual tuning of its rule sets to be effective and avoid overwhelming false positives, a process requiring a level of dedicated security expertise not yet present in this organization. The scenario specifies that the IT Security team, commissioned to perform this review, was "newly formed" and plainly states Northbridge has "no security awareness training program, no incident response process, and no policy" to underpin even rudimentary security operations - an open source IDS/IPS which essentially

becomes a piggybacking exercise for a dedicated in-house curation of rules to avoid false positives is arguably too great a burden to be reliably sustained by this organization at present. Second, Snort essentially operates as a stand-alone detection engine and does not offer the same level of centrally managed policy cohesiveness with the rest of the proposed architecture that the other products do have; to coordinate Snort's detection rules with existing Hub-and-Spoke branch firewalls and Cisco ISE's authentication-based segmentation would require additional integration effort rather than be unified out-of-the-box. Third, as a self-managed open source product, Snort does not carry any vendor support contract or accountability - for a financial institution actively looking to prepare a third party payment processor integration and the higher regulatory scrutiny that entails, to rely on an unsupported tool for a core detection/prevention control would introduce unnecessary compliance and audit risk, particularly given the scenario states there is no existing vendor security assessment process at Northbridge either.

Why Cisco Secure IPS Is the Better Fit for Northbridge Specifically

- Cisco Secure IPS directly addresses the scenario's stated blind spot by providing inline, signature- and anomaly-based detection and prevention, supported by constantly updated threat intelligence from Cisco Talos, as opposed to Northbridge's hypothetical in-house tuning capability (which is non-existent at present), while addressing the scenario's warning that ransomware incidents at comparable mid-sized financial firms have spread rapidly within an unsegmented network, as Cisco Secure IPS deployed at both the head office hub and branch-level firewalls (which are part of the Hub-and-Spoke architecture already proposed) will allow reconnaissance and active exploitation attempts to be detected and blocked at the branch level prior to further lateral spread having occurred, rather than only being visible post-damage, and it also natively integrates with the same Cisco firewall and Cisco ISE ecosystem selected for network architecture and AAA, allowing intrusion prevention policy to be centrally managed alongside segmentation and authentication policy rather than it being a disconnected, separately administered tool.

- Considering that Northbridge's highest immediate risk is the well-documented pattern of undetected compromise spreading throughout the network, while at the same time the company does not have the necessary expertise on staff to effectively maintain and tune an open-source alternative, I would recommend Cisco Secure IPS due to the managed threat intelligence, vendor accountability, and native integration the product offers the rest of the proposed architecture, at the slight increase in licensing costs.

Appendix B: Aaqib - IT24102514

VPN Proposal

Recommended Solution: FortiClient IPsec VPN (FortiGate NGFW Integration)

- Considering that Northbridge's highest immediate risk is the well-documented pattern of undetected compromise spreading throughout the network, while at the same time the company does not have the necessary expertise on staff to effectively maintain and tune an open-source alternative, I would recommend Cisco Secure IPS due to the managed threat intelligence, vendor accountability, and native integration the product offers the rest of the proposed architecture, at the slight increase in licensing costs..

Alternative Considered: Direct RDP (Remote Desktop) Access

- I considered allowing remote and travelling staff to connect directly via RDP to internal jump-host machines, since it requires no new VPN client rollout and staff are already familiar with remote desktop access.

Why Direct RDP Was Rejected for This Purpose

- Direct RDP exposure to the internet is one of the most common real-world ransomware entry vectors — attackers routinely scan for and brute-force exposed RDP ports, which is especially dangerous given Northbridge already has no MFA and a documented pattern of password reuse among staff. RDP alone provides no network-level segmentation or endpoint health checking before granting access, meaning an infected personal device (BYOD, already a named Northbridge weakness) could connect directly into internal systems. This would not solve Northbridge's root problem — it would just replace one unaccountable shared-access model with another equally risky one.

Why FortiClient IPsec VPN Is the Better Fit for Northbridge Specifically

- FortiClient integrates natively with FortiAuthenticator (the AAA solution proposed below) and FortiGate firewalls, meaning the same identity used for network authentication also governs VPN sessions — closing the "every device/application maintains its own local accounts" gap in one coherent system. Critically, FortiClient performs endpoint compliance checks (antivirus status, OS patch level) *before* granting a tunnel, directly mitigating the risk of unpatched or unmanaged personal devices connecting remotely — two separately named Northbridge weaknesses. If Northbridge's network architecture (below) already uses FortiGate firewalls at head office, this avoids introducing a second unrelated VPN vendor, reducing management overhead for a newly formed, still-maturing IT security team.

AAA Proposal

Recommended Solution: FortiAuthenticator with FortiToken MFA

- For centralized authentication, I recommend FortiAuthenticator, a RADIUS/LDAP-capable identity platform with built-in FortiToken multi-factor authentication, replacing Northbridge's current per-device local account model.

Alternative Considered: Microsoft Active Directory + Network Policy Server (NPS)

- I considered deploying a full Active Directory domain with NPS acting as the RADIUS server, since AD is the most widely used enterprise directory service and many staff would already be familiar with Windows domain logins.

Why AD + NPS Was Rejected for This Purpose

- Northbridge currently has no directory service at all — every device and application keeps separate local accounts. Standing up a full AD forest from scratch is a significantly larger, slower undertaking (domain controllers, schema planning, staff retraining) than Northbridge's newly formed IT security team can realistically absorb alongside the other urgent controls (segmentation, patching, training) competing for the same budget and timeline. NPS's native MFA support is also limited without licensing Azure MFA or a third-party add-on, meaning the explicitly named "no MFA anywhere" gap would still not be fully closed without extra cost. Additionally, placing a single Active Directory domain controller at head office recreates a single point of failure resembling today's flat-network risk — if that DC is compromised or unavailable, authentication fails organization-wide.

Why FortiAuthenticator Is the Better Fit for Northbridge Specifically

- FortiAuthenticator is a lighter-weight virtual appliance rather than a full domain infrastructure, better matching a 450-staff mid-sized bank with historically minimal IT investment. It ties directly into the same vendor fabric proposed for VPN (FortiClient) and can integrate with the network architecture's firewalls, giving one centralized identity source across VPN, Wi-Fi, and device logins. Built-in FortiToken MFA closes the MFA gap without a separate licensing negotiation, and RADIUS/LDAP support allows local accounts to be migrated gradually rather than requiring an all-at-once cutover — an important consideration given Northbridge's current lack of IT operational maturity.

Network Architecture Proposal

Recommended Solution: Three-Tier Zone Architecture (Perimeter + Internal + DMZ) at Head Office, with Zone-Based Firewall on Existing Branch Routers

- I recommend concentrating dedicated firewall enforcement at head office through a perimeter firewall, an internal firewall protecting the core banking zone, and a DMZ hosting the online banking portal/mobile app — combined with zone-based firewall (ZBFW) configuration on the routers already present at each branch, rather than purchasing separate dedicated firewall appliances for all six branches.

Alternative Considered: Hub-and-Spoke with a Dedicated Firewall Appliance at Every Branch

- I considered deploying a dedicated firewall appliance at each of the six branch offices in addition to head office, which would give every site independent, fully-featured enforcement.

Why Full Branch-Firewall Hub-and-Spoke Was Rejected for This Purpose

- Six additional dedicated firewall appliances represent a large capital and licensing commitment for an organization whose security investment has, per the scenario, "gone almost entirely into physical measures" rather than IT infrastructure. More importantly, Northbridge's IT security team is newly formed, has no formal patch management process, and no established change-management maturity — managing consistent policy across seven separate firewall appliances (six branches + HQ) introduces real risk of configuration drift and missed updates without a centralized management platform already in place to prevent it.

Why Three-Tier + Router-Based Zone Firewall Is the Better Fit for Northbridge Specifically

- This approach still directly addresses the specific risk pattern named in the scenario — ransomware spreading branch-to-branch across an unsegmented flat network — because zone-based firewall rules on each branch's existing router still separate guest Wi-Fi, POS equipment, and staff workstations locally, containing a compromised branch workstation before it can reach head office. At the same time, it avoids the cost and operational burden of six new dedicated appliances by reusing infrastructure Northbridge already has or is likely to upgrade anyway, while still giving the core banking database and customer-facing DMZ services the strongest, most concentrated protection at head office where the most critical assets live. This is a more realistic first phase for an organization at Northbridge's current IT security maturity, with room to upgrade to dedicated branch firewalls later.

IDS/IPS Proposal

Recommended Solution: Suricata (Open-Source IDS/IPS)

- I recommend Suricata, a high-performance open-source intrusion detection and prevention engine, deployed inline at the head office perimeter and as sensors at each branch, to close the scenario's explicitly named gap: no intrusion detection or prevention capability anywhere on the network.

Alternative Considered: Cisco Secure IPS (Commercial Next-Gen IPS)

- I considered Cisco Secure IPS, a fully commercial, vendor-supported inline IPS platform with strong integration into Cisco firewall/router infrastructure.

Why Cisco Secure IPS Was Rejected for This Purpose (in this individual proposal)

- Deploying a commercial IPS platform with licensing at head office and all six branches represents a significant recurring cost for a mid-sized bank that is simultaneously funding several other urgent, previously nonexistent controls (segmentation, centralized AAA, patch management, security awareness training) all at once. Given Northbridge's near-zero prior IT security investment, competing budget priorities make a large recurring licensing commitment on IDS/IPS alone harder to justify at this stage relative to open-source options with comparable core detection capability.

Why Suricata Is the Better Fit for Northbridge Specifically

- Suricata can run on standard virtual machines or commodity hardware at each branch rather than requiring dedicated proprietary appliances at all seven sites, meaningfully lowering upfront cost while Northbridge is still building foundational IT security capacity. Its open rule sets (e.g., Emerging Threats, Suricata/ET financial-sector rules) can be tailored to detect the exact reconnaissance and lateral-movement patterns described in the scenario, and its output integrates with common log-aggregation/SIEM tools — directly helping close the separately named "no centralized logging or audit trail" gap when paired with a logging pipeline. Being open-source also avoids locking Northbridge into one vendor's ecosystem this early, keeping flexibility to upgrade to a commercial platform later once budget and operational maturity increase.

Appendix C: Shaheen M F M - IT24102899

VPN Proposal

Recommended Solution: WireGuard-Based VPN (via Tailscale or a self-hosted WireGuard gateway)

- For Northbridge's secure remote access requirement, I recommend deploying a WireGuard-based VPN with per-user cryptographic keys and MFA enforced at the identity provider, providing individually authenticated remote access for travelling staff and the two external IT support contractors.

Alternative Considered: Palo Alto GlobalProtect

- I considered Palo Alto GlobalProtect, a fully commercial SSL/IPSec VPN client with strong endpoint posture-checking and integration into Palo Alto's broader security ecosystem.

Why Palo Alto GlobalProtect Was Rejected for This Purpose

- GlobalProtect's per-user licensing model scales into significant recurring cost across 450 staff plus fluctuating contractor access, at a moment when Northbridge is simultaneously funding several other urgent, previously nonexistent controls (segmentation, centralized AAA, IDS/IPS, awareness training) from a security budget that has historically gone almost entirely into physical measures. It also ties Northbridge into Palo Alto's proprietary ecosystem from day one, adding vendor lock-in and licensing complexity for a newly formed IT security team that is simultaneously standing up several other controls from scratch.

Why Wire Guard Is the Better Fit for Northbridge Specifically

- WireGuard's lightweight, modern cryptographic design and native key-per-device model gives every remote staff member and external contractor their own individually accountable credential, directly closing the scenario's named weakness of a single shared VPN account used interchangeably with no individual accountability and no MFA. Because WireGuard's configuration surface is small and auditable, it is easier for a still-maturing security team to deploy correctly and verify than a larger commercial client stack, and its low resource footprint means it can be layered on top of Northbridge's existing router infrastructure without requiring new dedicated VPN concentrator hardware at every site.

AAA Proposal

Recommended Solution: FreeRADIUS Integrated with a Centralized LDAP/Active Directory Directory

- For centralized authentication, I recommend FreeRADIUS backed by a consolidated LDAP/Active Directory directory, replacing Northbridge's current model in which every device and application maintains its own local set of user accounts.

Alternative Considered: Aruba ClearPass

- I considered Aruba ClearPass, a commercial RADIUS-based policy manager with strong built-in device profiling, capable of automatically detecting and classifying staff laptops, personal BYOD devices, and contractor machines.

Why Aruba ClearPass Was Rejected for This Purpose

- ClearPass's device-profiling capability is genuinely valuable, but it is a commercial platform with ongoing licensing costs, and more importantly it assumes a level of network access control maturity Northbridge doesn't yet have — the organisation currently has no centralized directory at all, only scattered local accounts on every device and application. Deploying ClearPass's advanced policy engine before that basic identity foundation exists would mean layering sophistication onto nothing.

Why FreeRADIUS + LDAP/AD Is the Better Fit for Northbridge Specifically

- This approach builds the missing identity foundation first — a real, centralized directory of staff, branch accounts, and contractor access — and layers RADIUS-based centralized authentication on top of it, matching Northbridge's actual current maturity level rather than assuming a policy infrastructure that doesn't yet exist. FreeRADIUS supports MFA integration and gradual account migration from the existing local-account model rather than requiring a disruptive all-at-once cutover, which matters given the scenario's explicit note that password reuse and sharing are already common among branch staff. Being open-source also avoids a large recurring licensing commitment while the organisation is simultaneously funding several other urgent controls.

Network Architecture Proposal

Recommended Solution: Defense-in-Depth Architecture with Function-Based Micro-Segmentation

- I recommend a perimeter firewall combined with an internal segmentation firewall that creates micro-segments by function — rather than a single broad "Internal" zone — separating HQ core banking systems, branch workstations, guest Wi-Fi, point-of-service equipment, and the incoming payment partner integration from one another.

Alternative Considered: Zero Trust / SASE Architecture

- I considered a full Zero Trust / SASE architecture with cloud-delivered firewall and per-application micro-segmentation, which authenticates and inspects every connection individually regardless of network location.

Why Zero Trust / SASE Was Rejected for This Purpose

- A full zero-trust/SASE architecture is arguably the strongest long-term model, but it typically assumes cloud-delivered infrastructure and an operationally mature security team capable of managing identity-aware, per-application access policies — a significant stretch for a newly formed IT security team with no prior segmentation experience at all. Attempting a full SASE rollout as a first step risks the exact kind of configuration drift and missed updates the scenario already warns about, given there is no established change-management maturity yet.

Why Function-Based Micro-Segmentation Is the Better Fit for Northbridge Specifically

- This approach directly targets the exact failure pattern described in the scenario: guest Wi-Fi, branch systems, and point-of-service equipment currently sit within reach of one another with no meaningful separation. Isolating each of these from core banking systems means a compromised branch workstation or an insecure guest device is contained locally rather than able to reach head office, while the new payment partner integration is placed in its own isolated zone ahead of go-live, given that no vendor security assessment process currently exists to vet the partners' security posture. This is a more realistic, achievable first phase for an organisation at Northbridge's current maturity level, with room to evolve toward a fuller zero-trust model later.

IDS/IPS Proposal

Recommended Solution: Zeek (Network Security Monitoring and Detection Engine)

- I recommend Zeek, an open-source network monitoring and protocol analysis engine, deployed at the perimeter and at the new partner integration chokepoint, to close the scenario's explicitly named gap: no intrusion detection or prevention capability anywhere on the network.

Alternative Considered: Darktrace

- I considered Darktrace, a commercial AI/ML-based Network Detection and Response platform that learns normal network behaviour and flags deviations, capable of catching novel or slow-moving reconnaissance that signature-based tools would miss.

Why Darktrace Was Rejected for This Purpose

- Darktrace's machine-learning-based detection is powerful, but it is a proprietary, subscription-priced product — another recurring cost layered on top of an organisation funding multiple urgent controls simultaneously from a near-zero security budget. It is also effectively a "black box" from an operational standpoint, which is a harder tool for a brand-new security team to tune, interpret, and trust in its first deployment compared to an open, inspectable tool.

Why Zeek Is the Better Fit for Northbridge Specifically

- Zeek is built primarily as a deep protocol-analysis and logging engine rather than a signature-matching tool, giving Northbridge the detailed, centralized activity record it currently has none of — directly addressing the named "no centralized logging or audit trail" gap, in addition to detecting the reconnaissance and lateral-movement behavior consistent with the ransomware pattern reported by the regional industry association. Because visibility has to exist before targeted blocking is meaningful, and Northbridge is currently blind to activity on its own network, establishing that monitoring foundation is the more urgent first step. Zeek's output can also be paired with the zone-based firewall already proposed for network architecture to add blocking capability where needed, reusing an existing control rather than introducing a separate enforcement mechanism.

Appendix D: Palugaswewa K I K I B - IT24201195

VPN Proposal

Recommended Solution: Palo Alto Networks GlobalProtect

- For Northbridge's secure remote-access requirement, I recommend Palo Alto Networks GlobalProtect deployed on Palo Alto Networks' next-generation firewalls. GlobalProtect provides per-user remote-access VPN, supports external authentication through RADIUS or SAML, and can use certificates and MFA. It can also place VPN traffic into a dedicated VPN security zone so remote-user access is controlled by explicit firewall policies.

Alternative Considered: OpenVPN Access Server

- OpenVPN Access Server was considered because it supports LDAP, RADIUS, SAML and built-in TOTP MFA, giving Northbridge a credible lower-cost and vendor-neutral remote-access option.

Why OpenVPN Access Server Was Rejected

- Northbridge needs remote access to sensitive financial systems, so integrating the VPN directly with the same firewall policy and security-zone controls used to protect those systems reduces the number of separate enforcement points.
- GlobalProtect supports individual authentication and MFA through RADIUS or SAML, directly replacing the shared VPN credential model.
- GlobalProtect can place remote users in a dedicated VPN zone and apply security policies between that zone and internal zones, supporting least-privilege access rather than broad internal reach.

Why GlobalProtect Fits Northbridge

- Directly addresses the shared-credential problem by authenticating individual remote users.
- Supports MFA through RADIUS or SAML and certificate-based two-factor authentication.
- Allows VPN traffic to be separated into a dedicated security zone and controlled by firewall policy.
- Can use endpoint HIP information for policy decisions where the required licensing is deployed.
- Provides a single enforcement point for remote-access authentication, VPN termination and internal access policy.

AAA Proposal

Recommended Solution: Aruba ClearPass Policy Manager

- For centralized authentication, authorization and accounting, I recommend Aruba ClearPass Policy Manager. ClearPass provides centralized RADIUS and TACACS+ services and can apply role- and device-based access policies across wired, wireless and VPN access. This is useful for Northbridge because the current environment has separate local accounts on devices and applications and no central authentication system.

Alternative Considered: FreeRADIUS with LDAP

- FreeRADIUS with LDAP was considered because it provides centralized RADIUS authentication without requiring a large commercial platform and can integrate with a directory as Northbridge develops one.

Why FreeRADIUS with LDAP Was Rejected

- It would require additional components and administration to provide the broader policy, device profiling and enforcement functions that Northbridge needs as it moves from isolated local accounts to centralized access control.
- Northbridge's security team is newly formed, so a platform with centralized policy management and reporting reduces the operational burden compared with assembling multiple separate services.
- ClearPass can apply authorization based on user and device context and support network access enforcement, making it more useful alongside the group's segmentation strategy.

Why ClearPass Fits Northbridge

- Centralizes authentication, authorization and accounting instead of maintaining isolated local accounts.
- Supports both RADIUS and TACACS+, covering user network access and administrative access to network infrastructure.
- Supports role- and device-based policies for employees, contractors and guest or unmanaged devices.
- Can assign different access levels to contractors and staff, helping prevent the shared VPN identity problem from returning.
- Can integrate with existing and future identity stores, allowing Northbridge to move toward a mature, centralized identity model without replacing every system at once.

Network Architecture Proposal

Recommended Solution: Secure SD-WAN Architecture with Distributed NGFW Zone Enforcement

- I recommend a secure SD-WAN architecture in which each branch has a security-capable SD-WAN edge/NGFW and the head office uses a redundant NGFW pair. The WAN overlay should carry branch traffic to defined security zones rather than allowing unrestricted branch-to-branch or branch-to-HQ communication. Critical services such as core banking, customer databases, payment-processor connectivity, staff workstations, POS systems, guest Wi-Fi and remote VPN users should occupy separate security zones.

Alternative Considered: Three-Tier Zone Architecture with Branch Zone-Based Firewalls

- This was considered because it places strong perimeter, internal and DMZ controls at head office while using existing branch routers for local zoning.

Why the Three-Tier + Branch ZBFW Model Was Not Selected

- It relies heavily on separate branch-router enforcement and does not provide the same centrally orchestrated WAN policy model across six branches.
- SD-WAN allows branch-to-HQ and branch-to-branch paths to be explicitly defined and centrally managed, reducing inconsistent routing or security policy between sites.
- Distributed NGFW enforcement allows traffic to be inspected and segmented closer to the branch workstation where a ransomware infection is likely to begin.

Why Secure SD-WAN Fits Northbridge

- Six branches make centralized policy and consistent security enforcement valuable as the network grows.
- Each branch can separate staff workstations, POS systems and guest Wi-Fi before traffic reaches the WAN.
- Branch-to-HQ traffic can be restricted to only the services required for core banking and approved business applications.
- Branch-to-branch communication can be denied by default, reducing ransomware's ability to spread between locations.
- The redundant head-office firewall pair protects the core banking and payment-integration zones while reducing a single-firewall failure risk.

IDS/IPS Proposal

Recommended Solution: Palo Alto Networks Advanced Threat Prevention

- For intrusion prevention, I recommend Palo Alto Networks Advanced Threat Prevention deployed inline on the NGFWs at the head office and branch security boundaries. This provides prevention within the same enforcement points used for segmentation and can detect and block malicious network activity, including exploitation and command-and-control traffic.

Alternative Considered: Zeek

- Zeek was considered because it provides strong network monitoring and rich protocol-level visibility and was already proposed by another group member. It is particularly useful for investigation and detection, but it is primarily a network security monitoring platform rather than a direct inline prevention control.

Why Zeek Was Not Selected

- Northbridge's immediate requirement is not only to observe attacks but to stop malicious traffic before it spreads through the network.
- Zeek would require additional enforcement technology to block detected traffic, creating another operational layer for a newly formed security team.
- Advanced Threat Prevention can operate inline on the NGFW and apply prevention policies at the same point where traffic between security zones is controlled.

Why Advanced Threat Prevention Fits Northbridge

- Provides inline prevention against exploits, malicious activity and command-and-control traffic.
- Can inspect traffic at branch and head-office security boundaries, supporting the ransomware containment objective.
- Works with the proposed zone-based architecture so detection and prevention occur where inter-zone traffic is already being controlled.
- Centralized management can keep prevention policy consistent across multiple NGFWs as Northbridge expands its security controls.
- Directly addresses Northbridge's current lack of any IDS/IPS capability.

Technical References

1. Palo Alto Networks - GlobalProtect documentation: external authentication, MFA and remote-access VPN.

2. Aruba Networking - ClearPass Policy Manager documentation: RADIUS/TACACS+, role-based and device-based network access control.

3. Palo Alto Networks - Network Security Zones documentation: segmentation and inter-zone policy enforcement.

4. Palo Alto Networks - Advanced Threat Prevention documentation: inline intrusion prevention and threat blocking.